Panduan Belajar Nusantara Shield — dari Nol sampai Bisa Menjelaskan

Oct 29, 2026 · @Pisang Muli

Cara Memakai Panduan Ini

Targetnya sederhana: setelah membaca dua belas bab ini, Bapak bisa menjelaskan Nusantara Shield kepada juri, atasan, atau orang awam **tanpa membuka catatan**, dengan kata-kata sendiri.

Seluruh panduan memakai satu analogi besar: **sebuah rumah sakit militer beserta pos jaganya**. Setiap istilah teknis akan dipasangkan dengan sesuatu di rumah sakit itu, sehingga yang diingat adalah gambarannya, bukan hafalan kata.

Urutan belajar yang disarankan:

1. **Bab 1–2 (pondasi):** apa itu dunia siber dan ancaman apa yang kita lawan. Belum ada istilah sulit.
2. **Bab 3–7 (inti):** apa yang dikerjakan Nusantara Shield, satu ide per bab. Ini bagian yang paling sering ditanya juri.
3. **Bab 8–9 (dapur):** cara kerja di balik layar. Cukup dipahami garis besarnya; juri teknis kadang menanyakannya.
4. **Bab 10 (panggung):** latihan menjelaskan dalam 30 detik dan 2 menit, serta jawaban untuk pertanyaan juri. Bab 11–12 (medan lomba): di mana sistem dipasang, siapa operatornya, dan prediksi pertanyaan per tipe juri.
5. **Kamus dan uji pemahaman** di akhir untuk mengulang.

Setiap bab ditutup dengan kotak **Kalimat siap pakai**: satu atau dua kalimat yang boleh langsung Bapak ucapkan.

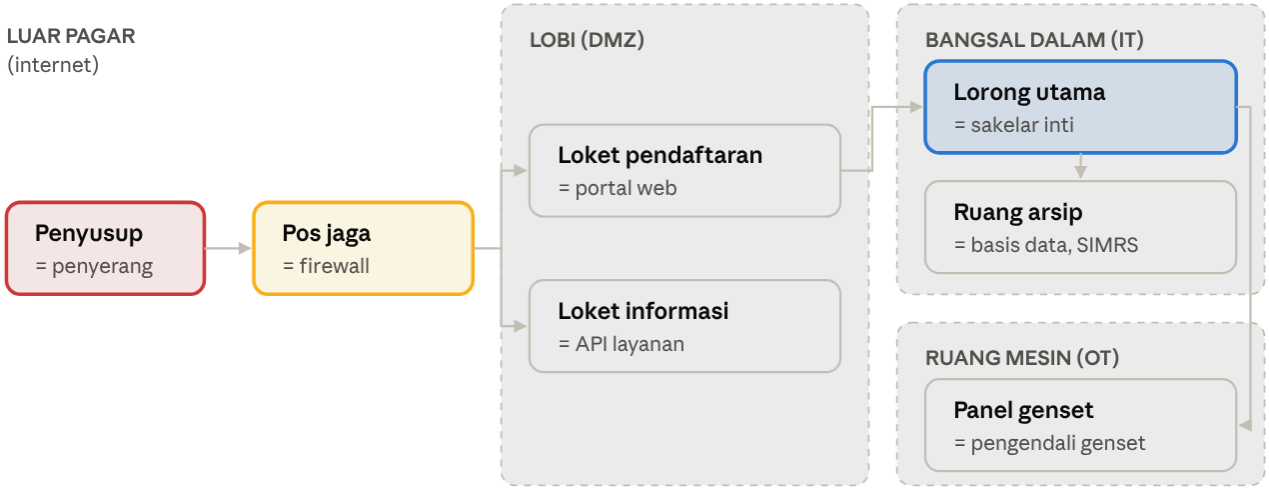
Satu prinsip yang dipegang sepanjang panduan: **jujur tentang batas**. Nusantara Shield adalah purwarupa latihan dengan data sintetis. Juri lebih menghargai tim yang tahu persis apa yang sudah dan belum dibangun daripada tim yang melebih-lebihkan.

Bab 1 — Dunia Siber dalam Satu Analogi

Dunia siber sebuah satuan bisa dibayangkan sebagai **rumah sakit militer yang punya banyak pintu, lorong, dan ruang**. Komputer adalah ruangan, kabel jaringan adalah lorongnya, dan data adalah barang berharga di dalam ruangan.

Istilah	Arti sederhana	Di rumah sakit
Aset	Perangkat atau sistem yang perlu dilindungi: komputer, server, basis data, genset	Ruangan dan peralatan penting
Jaringan	Sambungan yang membuat perangkat bisa saling bicara	Lorong dan pintu antarruang
Server	Komputer yang melayani komputer lain, misalnya menyimpan rekam medis	Gudang arsip pusat yang dilayani petugas
Alamat IP	Nomor unik setiap perangkat di jaringan, misalnya 192.0.2.120	Nomor kamar
Port	"Pintu" layanan tertentu di sebuah perangkat; tiap layanan punya nomor pintu sendiri	Loket di dalam kamar: loket 502 untuk genset, loket 3389 untuk akses jarak jauh
Penyerang	Orang atau kelompok yang masuk tanpa izin	Penyusup yang menyelinap lewat pintu yang tidak dijaga
Insiden	Kejadian keamanan yang mengganggu atau mengancam layanan	Kebakaran atau pencurian di rumah sakit

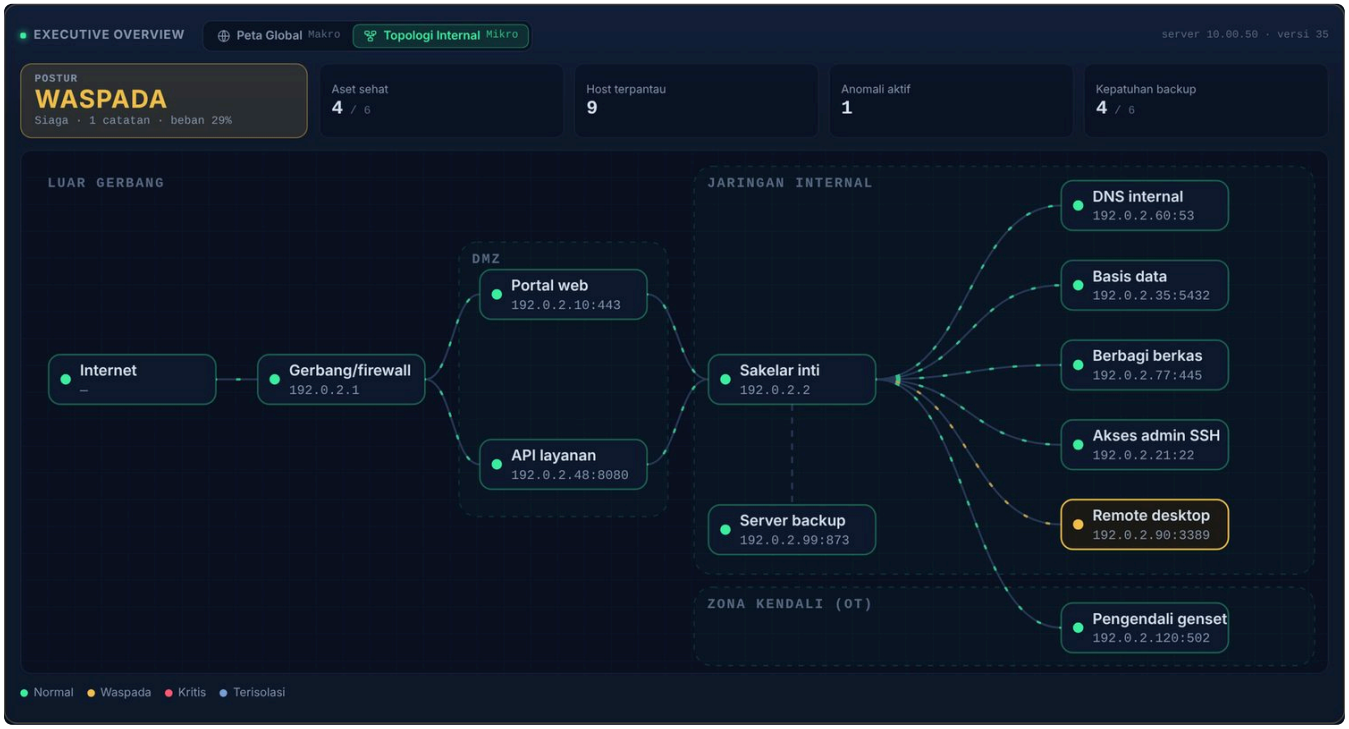
Jaringan satuan dibaca seperti denah rumah sakit



Penyusup harus melewati pos jaga, lobi, dan lorong sebelum sampai ke ruang arsip atau ruang mesin.
Tugas pertahanan: melihat setiap langkahnya dan menutup pintu sebelum ia sampai.

Analogi denah rumah sakit untuk jaringan satuan

Bandingkan dengan peta jaringan asli di dasbor Nusantara Shield di bawah ini. Susunannya sama: Internet di kiri, gerbang/firewall, DMZ (lobi), lalu jaringan internal dan Zona Kendali (OT) di kanan.



Topologi Internal di dasbor dalam keadaan normal. Setiap kotak adalah satu aset dengan alamat IP dan nomor port-nya; titik hijau berarti normal, kuning berarti waspada.

Tugas pertahanan siber mirip tugas regu jaga rumah sakit:

1. **Mengawasi** semua pintu dan lorong.
2. **Mengenali** gerak-gerik mencurigakan sebelum terjadi kerusakan.
3. **Menutup** pintu yang dilalui penyusup secepatnya.
4. **Mengamankan barang bukti** agar pelaku bisa ditelusuri.
5. **Memulihkan** ruangan agar layanan kembali berjalan.

Nusantara Shield adalah alat bantu bagi regu jaga itu. Kelima tugas di atas akan muncul lagi di bab-bab berikutnya dengan nama resminya.

> **Kalimat siap pakai:** "Bayangkan jaringan satuan sebagai rumah sakit dengan ratusan pintu. Nusantara Shield adalah pos jaga yang mengawasi semua pintu itu dari satu layar."

Bab 2 — Ancaman yang Kita Hadapi

Ancaman utama yang dilawan Nusantara Shield adalah ***ransomware***: program jahat yang **mengunci (mengenkripsi) data** lalu meminta tebusan agar kuncinya diberikan. Di rumah sakit, ini seperti penyusup yang menggembok semua lemari arsip dan pergi membawa kuncinya.

Dua istilah pendukung:

- **Enkripsi:** mengacak data dengan kunci rahasia sehingga tidak bisa dibaca tanpa kunci itu. Enkripsi sebenarnya alat pelindung; *ransomware* memakainya sebagai senjata.
- **Cadangan** (*backup*): salinan data yang disimpan terpisah. Kalau data asli dikunci penyusup, cadangan adalah jalan pulang. Karena itu penyusup sering mematikan cadangan lebih dulu.

Dua kejadian nyata di Indonesia

Kejadian	Apa yang terjadi	Pelajarannya
PDNS Surabaya, Juni 2024 (*ransomware* Brain Cipher)	Aktivitas penyusup sudah terekam dua hari sebelum enkripsi. Cadangan dimatikan tiga menit sebelum serangan. Hanya sekitar 2% data punya cadangan. Layanan imigrasi dan banyak instansi terganggu; tebusan diminta USD 8 juta.	Tanda bahaya sudah ada, tetapi tidak ada yang bertindak cepat.
BSI, Mei 2023 (dugaan *ransomware* LockBit 3.0)	ATM dan *mobile banking* terganggu 8–11 Mei. Analis menduga penyusupan dimulai sejak libur Lebaran. Pelaku mengklaim mencuri 1,5 TB data (belum terverifikasi).	Penyusup bisa berdiam lama tanpa ketahuan; pemulihan dikejar waktu.

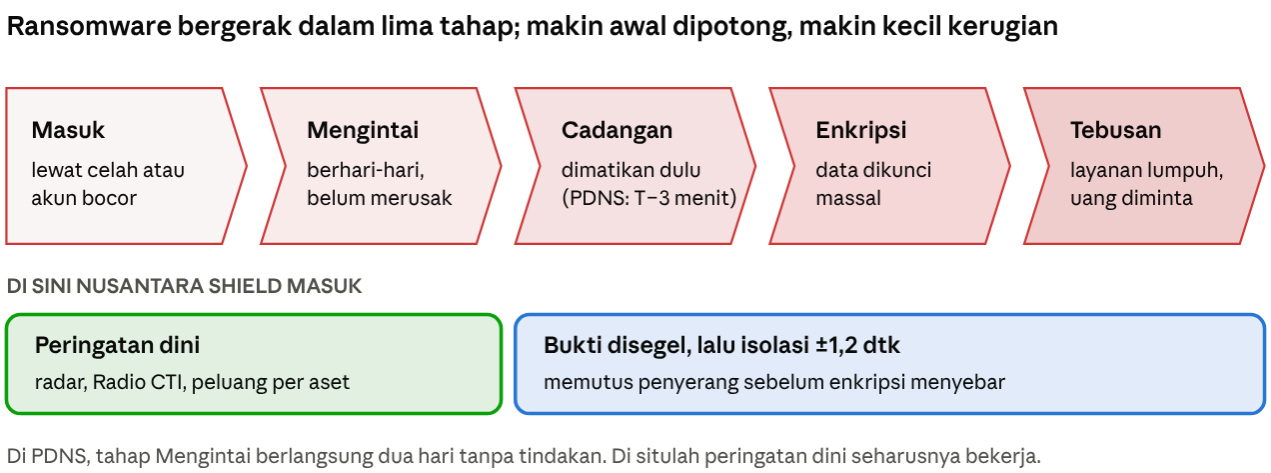


Ilustrasi PDNS (diolah dari detikINET dan CNBC Indonesia): penyusup masuk dua hari sebelumnya, cadangan dimatikan tiga menit sebelum enkripsi, dan hanya sekitar 2% data yang punya cadangan.



Ilustrasi BSI (diolah dari Bisnis.com, CISSReC, dan Vaksincom): layanan terganggu 8–11 Mei; klaim pencurian 1,5 TB adalah klaim pelaku dan belum terverifikasi.

Kedua kejadian mengikuti pola yang sama. Serangan *ransomware* jarang terjadi dalam satu langkah; ia bergerak bertahap, dan setiap tahap adalah kesempatan untuk memotongnya.



Tahapan serangan ransomware dan titik potongnya

Kenapa rumah sakit

Rumah sakit adalah tempat dua dunia bertemu: **komputer kantor** (rekam medis, pendaftaran pasien) dan **mesin fisik** (genset, pendingin udara, kelistrikan ruang operasi). Bab 6 akan membahasnya sebagai IT dan OT.

Dua fakta yang membuat proyeksi ini bukan khayalan:

- Pada Mei 2021, **279 juta data penduduk** dijual di forum peretas; sampelnya diduga kuat berasal dari BPJS Kesehatan. Data kesehatan bernilai tinggi bagi penyerang.
- Pada Agustus 2026, Health Sciences Centre di Winnipeg, Kanada, terkena *ransomware* yang mengenai **pendingin udara dan kendali akses pintu**. Pasien selamat karena jaringan klinis dan jaringan fasilitas dipisah.

> **Kalimat siap pakai:** "PDNS tidak lumpuh karena tidak ada tanda bahaya. Tanda itu sudah ada dua hari sebelumnya. Yang kurang adalah kecepatan bertindak. Bayangkan jika itu terjadi di rumah sakit satuan, yang dipertaruhkan bukan hanya data, tetapi nyawa."

Bab 3 — Apa Itu Nusantara Shield

Nusantara Shield adalah **dasbor pertahanan siber** untuk posko satuan: satu layar yang menampilkan kondisi seluruh jaringan, memberi peringatan dini, dan menjalankan langkah penanganan insiden secara berurutan. Di proposal, ia disebut **sistem pendukung keputusan (SPK)**, ibarat **Perwira Staf Siber Digital**: staf yang mengamati tanpa lelah dan menyiapkan pilihan, sementara keputusan tetap di tangan manusia. Ia **sengaja tidak otonom penuh**. Mesin mempercepat, manusia memutuskan.

> **Kalimat jati diri:** "Nusantara Shield: perisai pertahanan siber luring yang **mendeteksi**, **mencegah**, dan **membantu merespons**: memperingatkan lebih dulu, memutus dalam 1,2 detik, dan tidak pernah menghapus barang bukti."

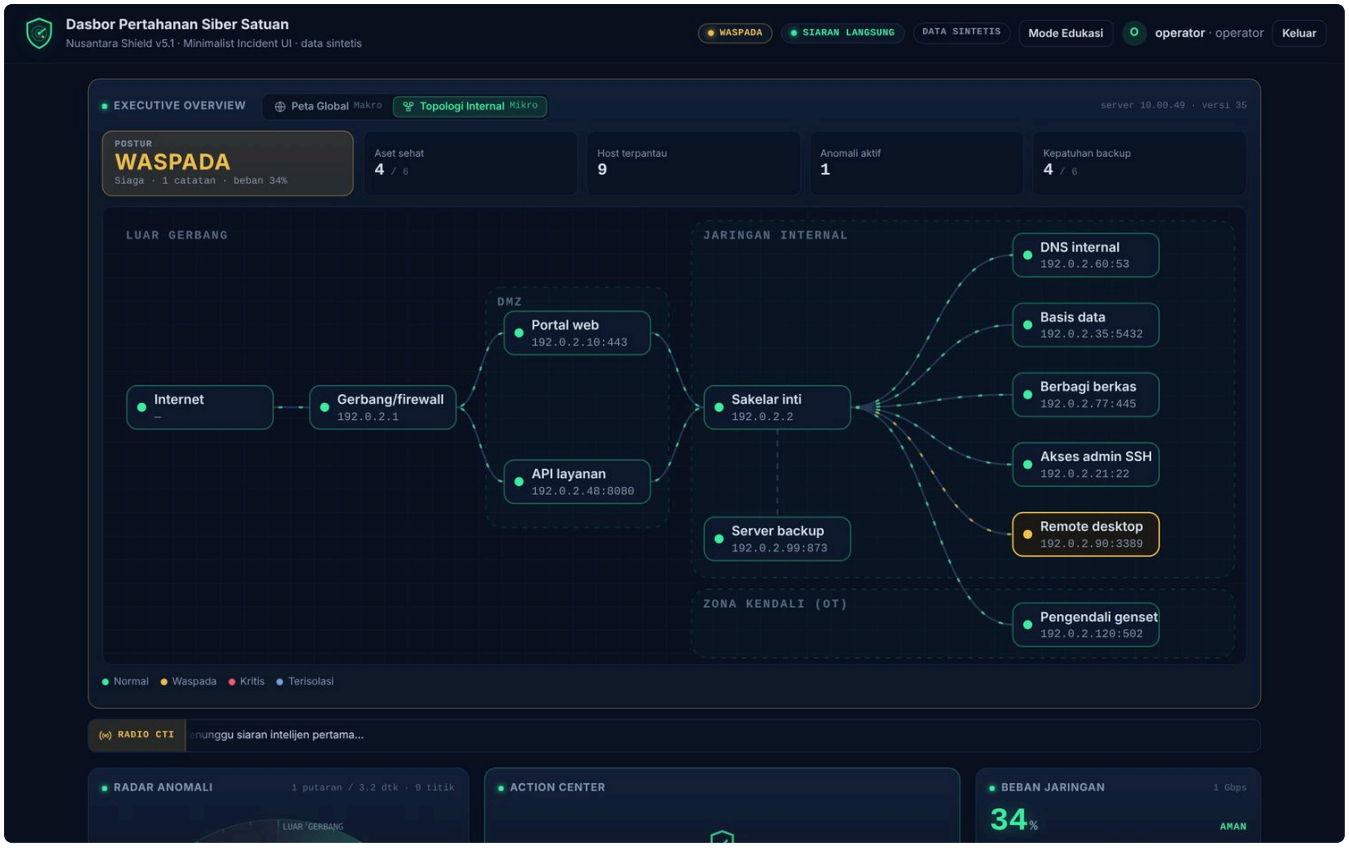
Tiga kata kerja itu adalah cara termudah mengingat isi kategori **Penangkalan (*Defensive Shield*)**: **mendeteksi** (aturan deteksi, AI lokal, kabar ancaman), **mencegah** (WASPADA dan Perketat sebelum diserang), dan **membantu merespons** (bukti → isolasi → LAPSIT yang berjalan otomatis setelah satu keputusan Operator). Kata "membantu" disengaja: yang memutuskan tetap manusia, dan di purwarupa perintah ke perangkat jaringan masih simulasi.

Nusantara Shield bekerja dalam **dua lapis**, dan saat menjelaskan kepada juri urutannya selalu begini:

1. **Lapis pertama: deteksi dan tangkal lebih dulu.** Kabar ancaman (CTI), AI lokal, dan aturan deteksi (*login* gagal berulang, pemindaian *port*) menaikkan aset berisiko ke **WASPADA** sebelum diserang; satu klik **Perketat** menurunkan risikonya (Bab 7). Inilah inti kategori **Penangkalan**.
2. **Lapis kedua: bila tetap tembus, bukti dulu, baru putus** dalam ±1,2 detik, tanpa mematikan genset (Bab 5 dan 6).

Urutan bab di panduan ini mengikuti urutan belajar (konsep bukti dibahas lebih dulu karena paling mendasar). Saat presentasi dan demo, mulailah dari lapis pertama.

Istilah dunia industrinya adalah **SOC** (*Security Operations Center*), yaitu pusat operasi keamanan. Di rumah sakit, SOC adalah **ruang kendali pos jaga** yang penuh layar CCTV.



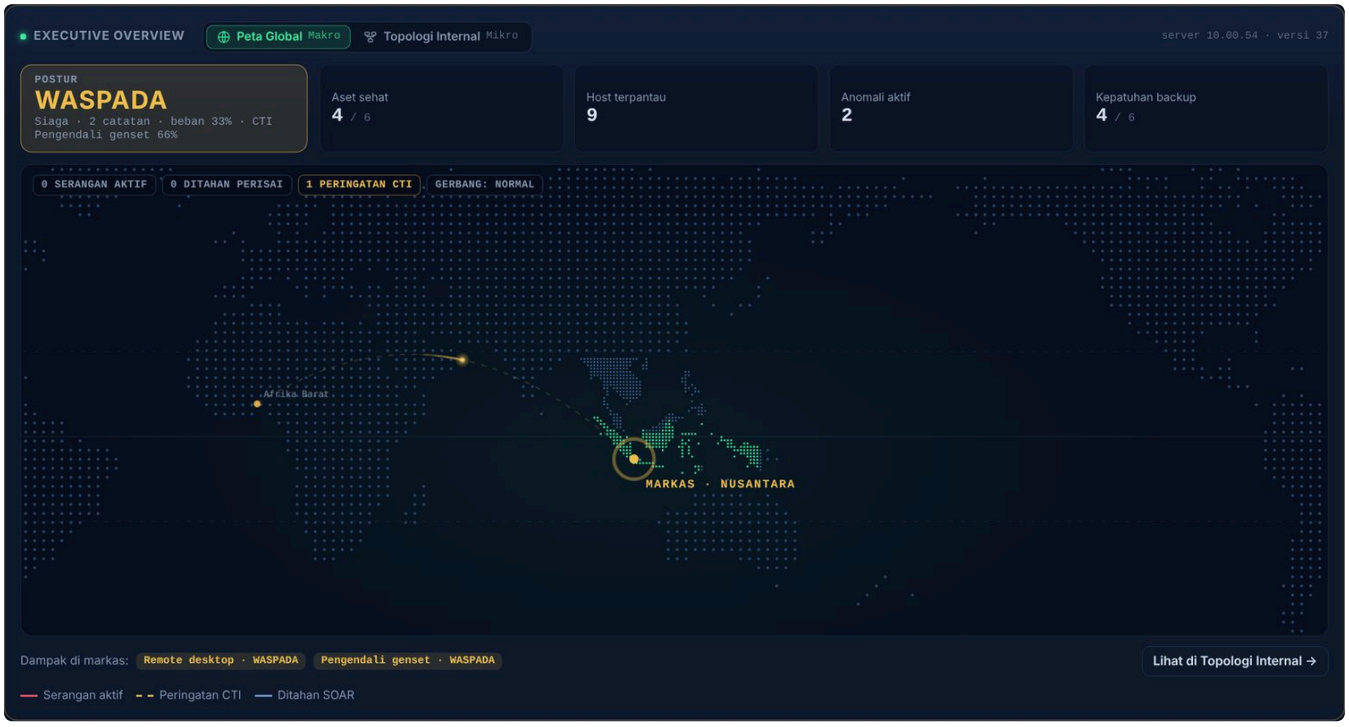
Layar utama setelah login sebagai operator. Di atas: judul "Dasbor Pertahanan Siber Satuan", lencana postur (WASPADA), tanda SIARAN LANGSUNG, dan DATA SINTETIS. Di tengah: Executive Overview dengan kotak postur, jumlah aset sehat, host terpantau, anomali aktif, dan kepatuhan cadangan, lalu Topologi Internal. Di bawah: pita Radio CTI, Radar Anomali, Action Center, dan Beban Jaringan.

Apa yang terlihat di layar

Bagian layar	Fungsinya	Analogi
Topologi	Peta semua perangkat dan kabel di antaranya, dibagi zona (kantor/IT dan kendali/OT)	Denah gedung rumah sakit
Radar Anomali	Titik-titik perangkat; makin dekat ke tengah, makin dalam posisinya di jaringan; warna menunjukkan bahaya	Layar radar di menara jaga
Radio CTI	Siaran kabar ancaman dari luar, misalnya "ada celah baru di protokol Modbus"	Radio informasi dari pos lain
Profil layanan	Kondisi tiap layanan (misalnya RS Kesdam · SIMRS dan Genset RS Kesdam) dan penanggung jawabnya	Papan status tiap bangsal

Bagian layar	Fungsinya	Analogi
Playbook	Daftar langkah baku penanganan insiden yang sudah disetujui	Prosedur tetap (protap) pemadaman kebakaran
Tombol isolasi	Tombol yang harus **ditahan 0,6 detik** untuk memutus jaringan aset bermasalah	Tuas penutup pintu darurat
LAPSIT	Laporan situasi yang terbit otomatis ke pimpinan	Laporan piket ke komandan

Selain Topologi Internal (tampilan mikro), ada tombol **Peta Global** (tampilan makro) yang menunjukkan dari mana ancaman datang.



Peta Global: garis putus-putus kuning adalah peringatan CTI yang sedang dipantau menuju "Markas · Nusantara". Di bawah peta tertulis aset markas yang terdampak (Remote desktop dan Pengendali genset, keduanya WASPADA). Asal negara di peta ini ilustratif karena semua datanya sintetis.

Siapa yang memakainya

- **Pengamat:** hanya boleh melihat. Cocok untuk pimpinan yang ingin memantau.
- **Operator:** boleh bertindak (mengisolasi, memulihkan). Akun operator hanya bisa dibuat dengan kode undangan atau oleh operator lain.

Batas yang perlu diingat

Semua data di purwarupa adalah **data contoh (sintetis)**. Alamat IP-nya memakai blok khusus dokumentasi (RFC 5737, misalnya 192.0.2.x dan 203.0.113.x) yang memang tidak dipakai di internet sungguhan. Nama orang dan satuan juga fiktif. Jadi aman didemonstrasikan di depan umum.

Nama aset contoh kini disesuaikan dengan lingkungan TNI AD: **Portal RSPAD**, **Portal Alkes Kesdam**, **Keuangan Markas**, **RS Kesdam** (SIMRS), **Genset RS Kesdam**, dan **Gudang Kesdam**. Beberapa tangkapan layar di panduan ini diambil sebelum penamaan ulang, sehingga masih menampilkan nama lama seperti "Rumah Sakit Pemerintah" atau "Fasilitas RS". Fungsi dan alurnya sama persis.

Apa yang sudah berjalan dan apa yang masih rencana. Bedakan ini dengan tegas setiap kali menjelaskan:

Sudah berjalan di purwarupa v5.1	Belum dibangun (peta jalan: Mode Hybrid dan eskalasi)
Operasi luring penuh di satu satuan/rumah sakit (*on-premise*)	**(1) Pengiriman LAPSIT otomatis berjenjang** ke Sandi dan Siber Kodam (Sansidam) dan Kartika CSIRT (Pussiberad)
Dua peran: Pengamat dan Operator	**(2) Akses dan tampilan lintas satuan** untuk pemantauan serentak di Mabes
Isolasi dengan tombol yang ditahan 0,6 detik	Engine Asisten Narasi: LLM lokal Llama 3 8B lewat Ollama untuk draf LAPSIT
Rantai bukti HMAC-SHA256	Umpan indikator resmi (BSSN/MISP) lewat gerbang satu arah
Korelasi CTI dan Engine Deteksi Anomali (*Isolation Forest*, luring)	Sensor nyata (Wazuh, Suricata, Zeek) dan sakelar terkelola sungguhan
Simulasi OT genset (Modbus, *port* 502)	Peristiwa identitas nyata dari Active Directory (perubahan hak akses, akun baru)
Pembuatan LAPSIT dan ekspor PDF	**Respons bertingkat menurut kritikalitas aset:** aset vital tetap dua kunci; *endpoint* kantor berisiko rendah diisolasi otomatis dengan praotorisasi
Engine Deteksi Aturan: login gagal berulang, login tembus, pemindaian port (atas peristiwa sintetis)	

Sudah berjalan di purwarupa v5.1	Belum dibangun (peta jalan: Mode Hybrid dan eskalasi)
Linimasa 60 menit (data latihan), pita anomali AI per aset, KPI MTTC dan insiden	

> **Kalimat siap pakai:** "Nusantara Shield adalah ruang kendali pos jaga dalam bentuk satu layar. Mesin mengamati dan menyiapkan; manusia yang memutuskan."

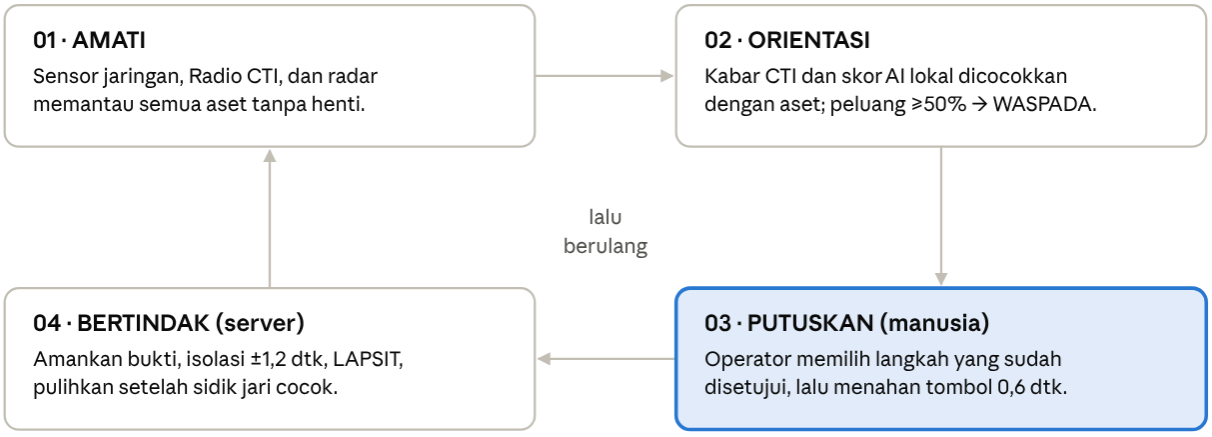
Batasan penggunaan

> Nusantara Shield adalah alat **defensif murni** untuk memantau dan melindungi **aset milik satuan sendiri**.
>
> - Tidak memindai, menguji, atau mengakses sistem pihak lain. Mengakses sistem elektronik orang lain tanpa hak dilarang Undang-Undang Informasi dan Transaksi Elektronik (UU ITE) Pasal 30.
> - Di purwarupa, seluruh data sintetis. Saat dipasang sungguhan, *log* dan barang bukti dapat memuat data pribadi pasien dan personel. Pengelolaannya mengikuti semangat Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP): hanya data yang diperlukan, disimpan di *server* satuan, dan aksesnya dibatasi peran.
> - Isolasi hanya dapat dijalankan Operator atas aset di inventaris satuan, sesuai *playbook* yang sudah disetujui pimpinan.

Bab 4 — Siklus OODA

OODA adalah cara berpikir militer untuk mengambil keputusan: **Amati → Orientasi → Putuskan → Bertindak**, lalu berulang. Gagasannya dari Kolonel John Boyd (Angkatan Udara Amerika Serikat): pihak yang menyelesaikan siklus ini lebih cepat akan unggul. Di dunia siber, "lebih cepat" berarti menutup pintu sebelum penyusup sempat mengunci data.

Mesin mengamati dan menyiapkan, manusia memutuskan, server bertindak



Siklus OODA di Nusantara Shield · 4 tahap

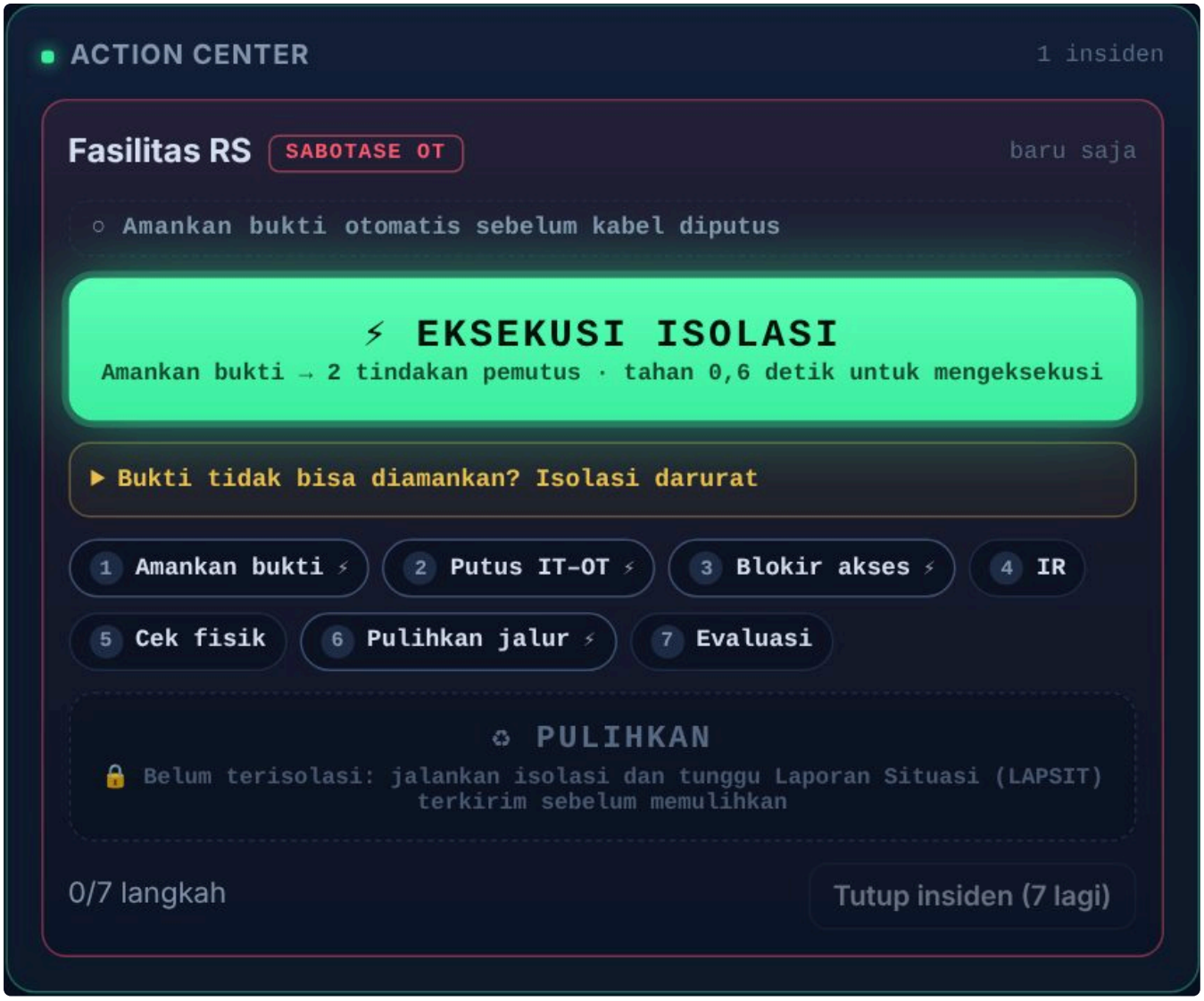
Seluruh desain Nusantara Shield adalah usaha mempercepat keempat tahap itu, tanpa mengambil keputusan dari tangan manusia.

Tahap	Pertanyaan komandan	Yang dikerjakan Nusantara Shield
Amati (*Observe*)	Apa yang terjadi di jaringan?	Topologi, radar, dan Radio CTI dalam satu layar.
Orientasi (*Orient*)	Apakah ini menyangkut aset kita?	Mencocokkan kabar ancaman dengan daftar aset dan menghitung **peluang serangan per aset**.
Putuskan (*Decide*)	Tindakan apa yang diizinkan?	*Playbook* **praotorisasi**: langkah sudah disetujui sebelumnya, operator cukup menahan tombol.
Bertindak (*Act*)	Bagaimana bertindak tanpa merusak bukti?	Server menjalankan urutan terkunci: bukti → isolasi → laporan → pemulihan.

Dua istilah penting dari tabel di atas:

- **Praotorisasi** (*pre-authorized*): izin diberikan **sebelum** kejadian, saat suasana tenang. Ketika insiden datang, operator tidak perlu menunggu tanda tangan berjenjang. Analoginya protap kebakaran: petugas boleh langsung menekan alarm tanpa menelepon direktur dulu.
- **Tahan tombol 0,6 detik:** bukan klik biasa. Menahan tombol mencegah salah pencet saat panik, tetapi tetap jauh lebih cepat daripada jendela "Anda yakin?".

Seperti inilah tahap **Putuskan** di layar. Begitu insiden masuk, Action Center menampilkan satu tombol besar beserta urutan langkah *playbook* yang sudah disetujui:



Action Center saat Sabotase OT masuk. Tombol hijau EKSEKUSI ISOLASI bertuliskan "tahan 0,6 detik untuk mengeksekusi". Di bawahnya tujuh langkah playbook; langkah bertanda ⚡ dijalankan otomatis oleh server. Tombol Pulihkan masih terkunci karena aset belum terisolasi.

> **Kalimat siap pakai:** "PDNS tertinggal di tahap Amati dan Orientasi: tanda bahaya ada, tetapi tidak dikenali dan tidak ditindaklanjuti. Nusantara Shield mempercepat keempat tahap OODA, tetapi tombol keputusan tetap di tangan operator."

Bab 5 — Rantai Bukti Forensik: Bukti Dulu, Baru Putus

Prinsip paling khas Nusantara Shield: **barang bukti diamankan sebelum jaringan diputus, dan pemulihan dikunci sampai bukti terbukti utuh.** Tanpa bukti, insiden tidak bisa ditelusuri, pelaku tidak bisa dibuktikan, dan pelajaran tidak bisa diambil.

Analoginya polisi di tempat kejadian perkara. Polisi memasang garis polisi dan memotret lokasi **sebelum** barang dipindahkan. Kalau petugas kebersihan datang lebih dulu dan mengepel lantai, jejak sepatu pelaku hilang selamanya. Dalam insiden siber, "mengepel lantai" itu bisa berupa me-*restart* server atau memulihkan dari cadangan terlalu cepat.



Gambar dari Proposal: empat langkah yang urutannya dikunci server.

Istilah kunci

- **Forensik digital:** ilmu mengumpulkan dan memeriksa bukti dari perangkat komputer, mirip forensik di kepolisian.
- **Barang bukti digital:** isi memori, catatan kejadian (*log*), dan rekaman lalu lintas jaringan. Isi memori hilang bila komputer dimatikan, jadi harus diambil lebih dulu.
- ***Chain of custody* (rantai penguasaan bukti):** catatan siapa memegang bukti, kapan, dan apa yang dilakukan. Tanpa rantai ini, bukti bisa dianggap tidak sah.
- **SHA-256 (sidik jari digital):** rumus yang mengubah isi berkas menjadi deretan 64 karakter. Isi berubah satu huruf saja, sidik jarinya berubah total. Istilah umumnya *hash*.
- **HMAC (segel bertanda kunci):** sidik jari yang dibuat dengan kunci rahasia. Setiap catatan di buku audit menyimpan segel catatan sebelumnya, sehingga membentuk rantai.
- **Berita acara (BB-2026-001):** nomor resmi barang bukti, terbit otomatis setelah bukti disegel.



Sidik jari SHA-256 dan rantai segel HMAC

Bagaimana prinsip ini dikunci di server

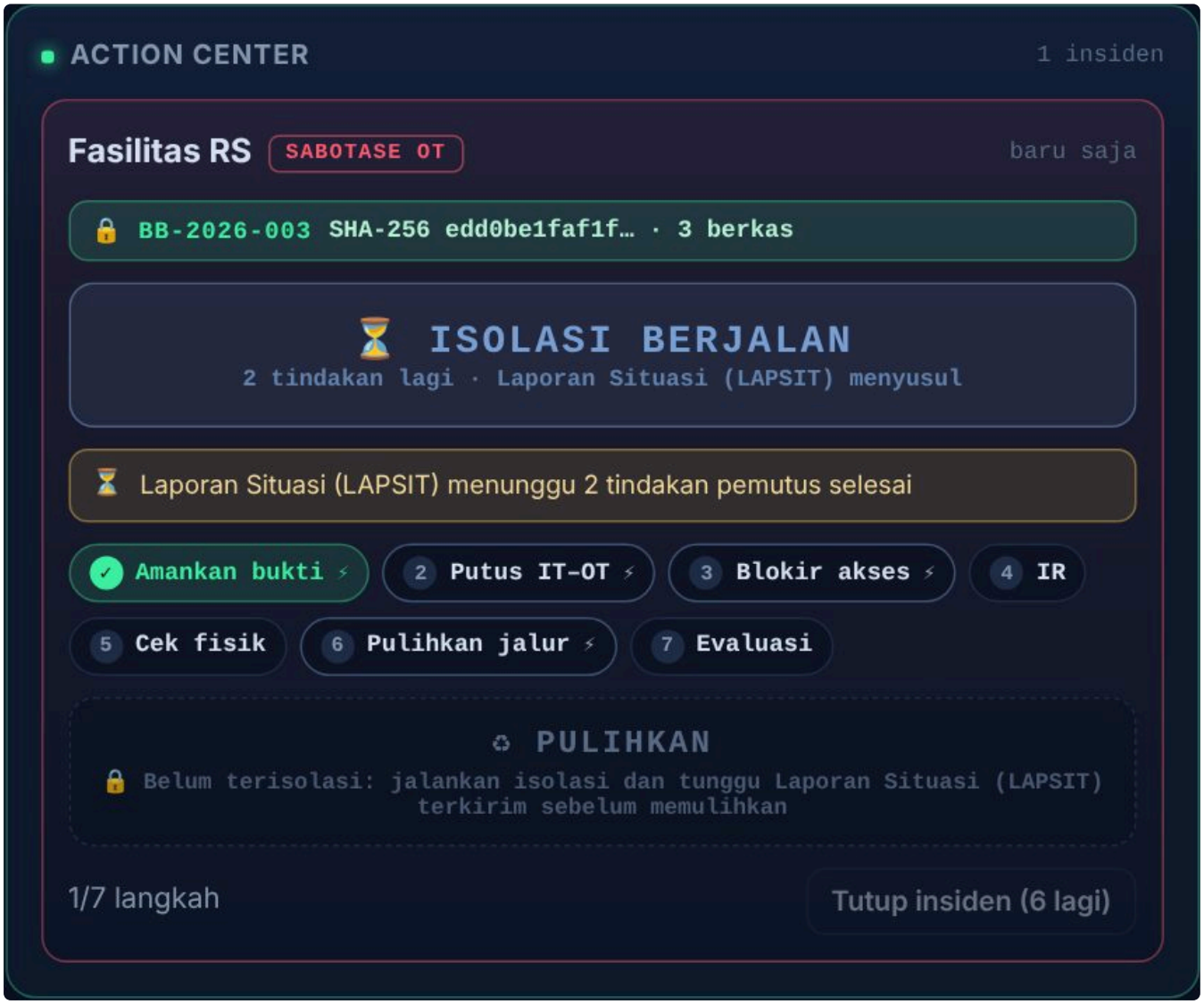
1. Operator menahan tombol isolasi. Server **lebih dulu** mengambil salinan memori, *log*, dan lalu lintas jaringan, lalu menghitung sidik jari SHA-256 setiap berkas.
2. Sekitar **1,2 detik** kemudian, barulah jaringan aset diputus. Setiap upaya memutus jaringan tanpa bukti **ditolak server dengan kode 409**, lewat jalur apa pun.
3. Tombol **Pulihkan** terkunci. Kuncinya baru terbuka bila aset sudah terisolasi, langkah *playbook* dicentang, dan sidik jari bukti **dicocokkan ulang**. Kalau ada yang mengubah bukti, hasilnya "TIDAK COCOK" dan pemulihan tetap terkunci.

> **Rujukan standar: ISO/IEC 27037.** Urutan di atas disusun **mengikuti prinsip** International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) 27037:2012, standar internasional tentang identifikasi, pengumpulan, akuisisi, dan pelestarian bukti digital. Kaitannya: bukti diambil sebelum kondisi aset berubah (akuisisi), disegel SHA-256 agar keutuhannya bisa diperiksa ulang (pelestarian), dan setiap tindakan tercatat di buku berantai HMAC beserta berita acaranya (dapat diaudit). LAPSIT memuat nomor dan sidik jari bukti itu. Ucapkan "mengikuti prinsip", **bukan** "patuh" atau "tersertifikasi": purwarupa belum diaudit pihak ketiga, dan pengambilan bukti di purwarupa masih disimulasikan.

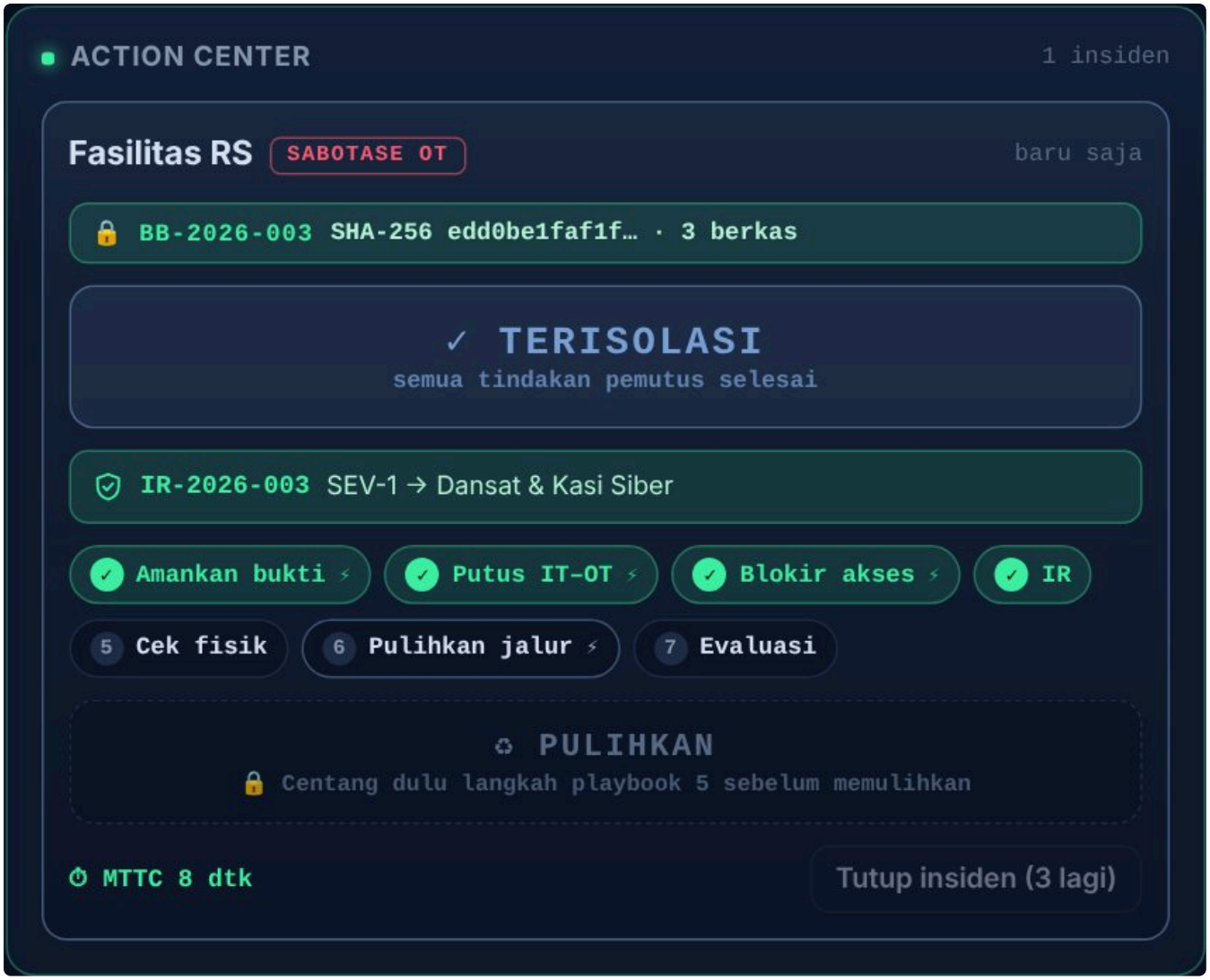
Diperiksa tanpa menyalakan server. Auditor tidak perlu memercayai *server* untuk memeriksa *server*. Alat `tools/verifikasi_audit.py` membaca berkas log audit dan Buku Rantai Bukti, lalu menghitung ulang seluruh rantai HMAC-SHA256 dengan kunci yang sama. Alat ini hanya memakai pustaka bawaan Python, tidak mengimpor kode aplikasi, dan

tidak membuka jaringan. Bila ada yang diubah, alat menyebut letaknya, misalnya "Sidik jari entri #2 tidak cocok". Satu hal yang tidak bisa dilihat rantai saja adalah entri yang dipotong di ujung berkas. Karena itu sidik jari yang tercetak di LAPSIT dicocokkan lewat `--cocokkan`: bila tidak ditemukan, log sudah dipotong atau diganti.

> **Kalimat siap pakai:** "Laporan kami bisa diaudit tanpa memercayai sistem kami. Bawa berkas log dan kuncinya, jalankan satu perintah, dan setiap coretan ketahuan beserta nomor halamannya."



Tangkapan layar dasbor sesaat setelah tombol ditahan: baris hijau teratas adalah bukti yang sudah disegel (3 berkas), di bawahnya isolasi sedang berjalan dan LAPSIT menunggu.



Beberapa detik kemudian: status TERISOLASI, laporan IR-2026-003 terkirim ke Dansat dan Kasi Siber, dan tombol Pulihkan masih terkunci sampai langkah 5 dicentang.

Jalan darurat

Bagaimana kalau alat forensik sendiri rusak saat serangan menyebar? Tersedia **Isolasi Darurat** (*Emergency Override*): operator wajib menulis alasan minimal 15 karakter dan menahan tombol 1,5 detik. Jalan ini hanya terbuka bila bukti **belum** bisa diamankan, dan tetap tercatat di tiga tempat: buku rantai bukti, *log* audit, dan LAPSIT. Pemulihan tetap terkunci sampai bukti susulan diamankan.



Gambar dari Dokumentasi Teknis: alur baku F-04 dengan gerbang server di antara setiap langkah.

> **Kalimat siap pakai:** "Kebanyakan sistem berlomba memutus jaringan secepatnya, lalu buktinya hilang. Nusantara Shield menyegel bukti dulu dengan sidik jari SHA-256, baru memutus 1,2 detik kemudian. Pemulihan pun dikunci sampai sidik jari itu dicocokkan ulang."

Bab 6 — IT dan OT: Komputer Kantor dan Mesin Fisik

Rumah sakit menjalankan dua jenis teknologi yang sifatnya berbeda, dan Nusantara Shield menjaga keduanya dalam satu layar.

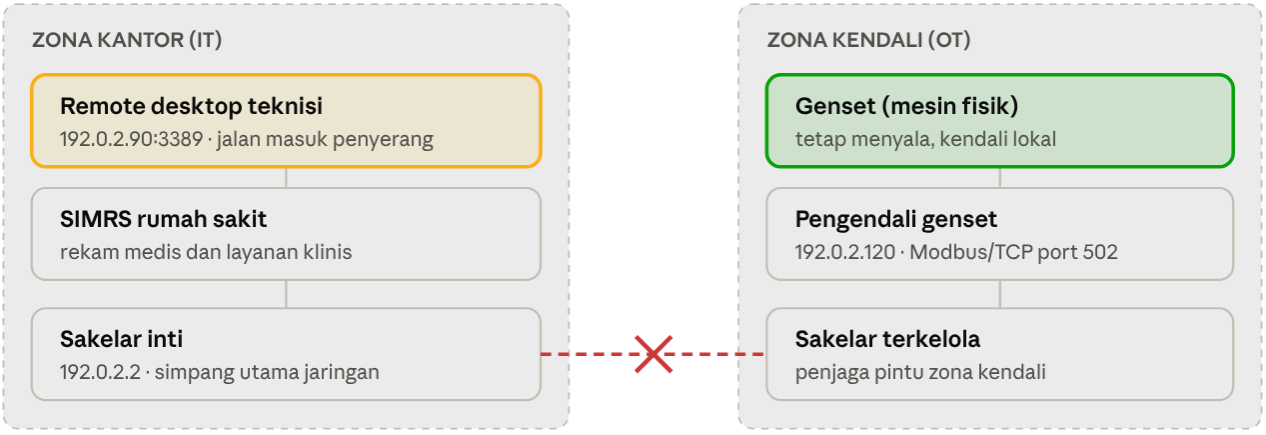
	IT (*Information Technology*)	**OT** (*Operational Technology*)
Mengurus	Data dan informasi	Mesin dan proses fisik
Contoh di rumah sakit	SIMRS, rekam medis, pendaftaran pasien, surel	Genset, pendingin udara, kelistrikan ruang operasi, lift
Kalau diserang	Data dikunci atau dicuri	Mesin berhenti atau bergerak salah; bisa membahayakan nyawa
Analogi	Bagian administrasi dan arsip	Ruang mesin dan panel listrik di basemen

Konvergensi IT/OT artinya kedua dunia ini kini tersambung ke jaringan yang sama, supaya mesin bisa dipantau dari kantor. Praktis, tetapi pintunya jadi terbuka: penyerang yang masuk lewat komputer kantor bisa menyeberang ke ruang mesin.

Istilah kunci

- **Modbus:** "bahasa" yang dipakai mesin industri untuk saling memberi perintah. Lahir pada 1979, sebelum ada ancaman siber, sehingga **tidak memeriksa siapa pengirimnya**. Siapa pun yang sudah masuk jaringan bisa memberi perintah. Di Nusantara Shield, pengendali genset memakai Modbus di *port* 502.
- **Pengendali genset:** komputer kecil yang menyalakan, mematikan, dan mengatur genset.
- **Zona:** pembagian jaringan menjadi wilayah dengan pintu penjaga di antaranya. Panduan keamanan sistem kendali industri NIST SP 800-82 menganjurkan zona OT dipisah dari zona kantor.
- **Sakelar terkelola** (*managed switch*): perangkat simpang jaringan yang sambungannya bisa dibuka-tutup dari jauh. Ia penjaga pintu zona kendali.
- ***Uplink*****:** kabel penghubung dari jaringan kantor ke zona kendali.
- ***Webhook*****:** pesan otomatis dari satu sistem ke sistem lain, seperti SMS perintah otomatis. Nusantara Shield mengirim *webhook* ke sakelar terkelola untuk memutus *uplink*. **Di purwarupa, *webhook* ini masih simulasi.**

Saat Sabotase OT, yang diputus jalurnya, bukan listriknya



× Uplink kantor → zona kendali diputus lewat sakelar terkelola (di purwarupa: simulasi webhook).

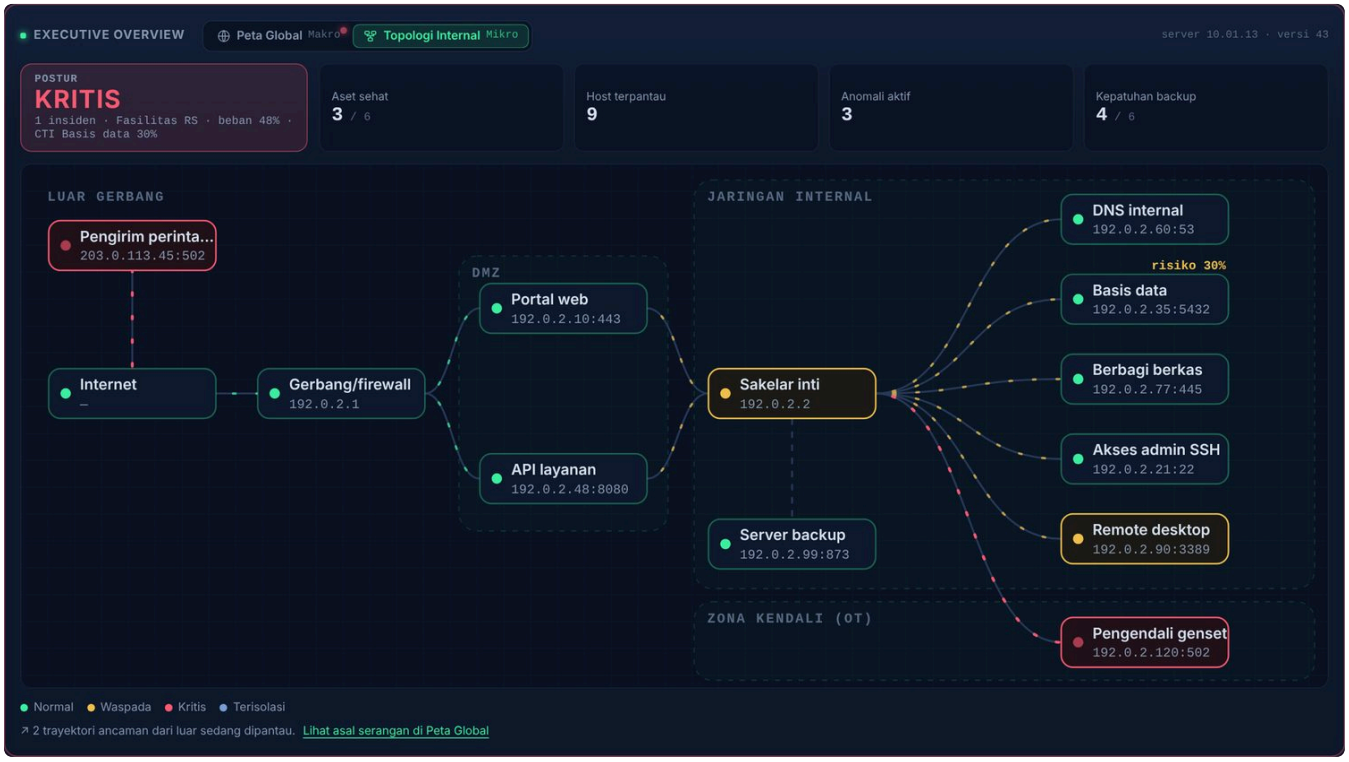
Jalur serangan: penyerang → remote desktop teknisi → sakelar inti → perintah Modbus ke pengendali genset.

Zona IT dan OT saat skenario Sabotase OT

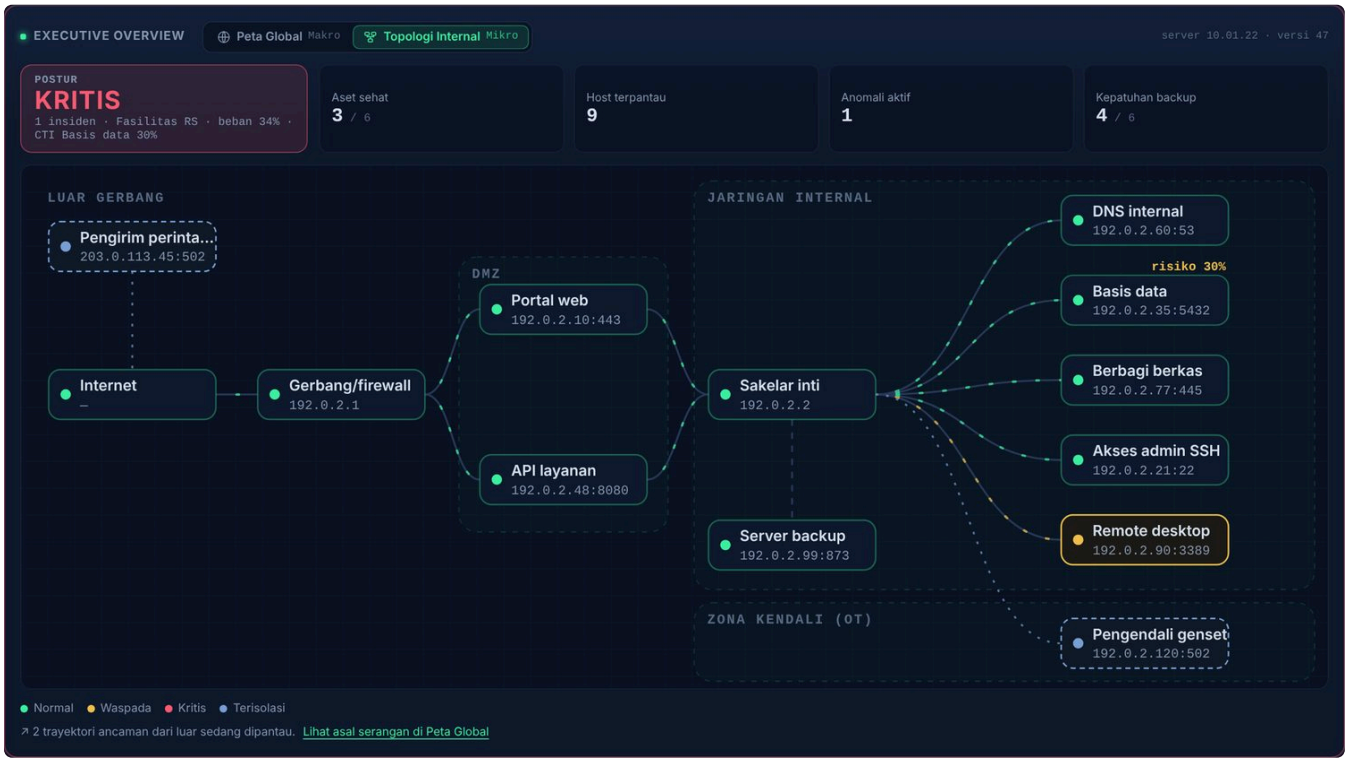
Kenapa genset tidak dimatikan saja

Karena ruang operasi, ICU, dan lemari obat bergantung padanya. Mematikan genset untuk menghentikan peretas sama saja dengan memadamkan rumah sakit sendiri. Jadi yang diputus adalah **jalur jaringannya**: perintah dari kantor tidak bisa lagi sampai, sementara genset tetap menyala dengan kendali lokal. Setelah itu petugas melakukan **cek fisik** ke ruang genset (langkah 5 *playbook*).

Seperti apa di layar



Skenario Sabotase OT baru dimulai: pengendali genset di Zona Kendali (OT) menyala merah, dan postur berubah menjadi KRITIS.



Setelah operator menahan tombol: bukti disegel, lalu jalur ke Zona Kendali diputus. Kotak pengendali genset kini biru bergaris putus-putus, artinya terisolasi, dan pengirim perintah asing di Luar Gerbang ikut diblokir. Akses jarak jauh teknisi dicabut (tercatat di Log), meski kotaknya tetap kuning karena masih berstatus waspada.

> **Kalimat siap pakai:** "Di rumah sakit, mematikan genset bukan pilihan. Nusantara Shield memutus jalan masuknya, bukan listriknya: jalur kantor ke zona kendali diputus lewat sakelar terkelola, sementara genset tetap menyala dengan kendali lokal."

Bab 7 — Intelijen Ancaman: Tahu Lebih Dulu

Bab ini menjawab tahap **Orientasi** di siklus OODA: dari ratusan kabar ancaman di luar sana, mana yang benar-benar menyangkut aset kita? Nusantara Shield menjawabnya dengan menghitung **peluang serangan per aset**, lalu menaikkan aset berisiko ke status **WASPADA** sebelum serangan datang.

Istilah kunci

- **CTI** (*Cyber Threat Intelligence*): kabar ancaman siber dari luar, misalnya "kelompok X sedang mengincar celah di protokol Modbus". Analoginya radio informasi antarpos jaga.
- **OSINT** (*Open Source Intelligence*): intelijen dari sumber terbuka, seperti berita, forum, dan laporan publik.
- **IOC** (*Indicator of Compromise*): jejak yang menandai penjahat, misalnya alamat IP penyerang, nama domain palsu, atau sidik jari berkas jahat. Analoginya foto dan ciri-ciri buronan di pos satpam.
- **Korelasi:** mencocokkan kabar ancaman dengan daftar aset sendiri. Kabar tentang *port* 502 hanya relevan bagi aset yang membuka *port* 502.
- **Kelelahan peringatan** (*alert fatigue*): petugas kewalahan oleh ratusan peringatan sampai yang penting terlewat. Korelasi mencegahnya dengan hanya menaikkan aset yang benar-benar terkait.
- **Perketat** (*hardening*): menutup pintu yang tidak perlu agar aset tidak mudah diserang. Di purwarupa, satu klik Perketat memotong paparan aset sebesar 70%.

Bagaimana peluang dihitung

Empat angka dikalikan: seberapa yakin sumber kabarnya, seberapa terbuka asetnya, seberapa baru kabarnya, dan bonus 10% bila sektornya sama. Hasil 50% ke atas membuat aset naik WASPADA.

Kabar Modbus menaikkan genset ke WASPADA; Perketat menurunkannya

Contoh nyata di purwarupa: kabar CTI-109 (celah protokol Modbus) bertemu pengendali genset

Keyakinan	×	Paparan	×	Kesegaran	×	Bonus sektor	=	Peluang
0,80		0,75		1,0		1,1		≈66%
seyakin apa sumber		seterbuka apa aset		kabar masih baru		sektor sama (energi)		di atas ambang 50%

Sebelum: genset naik WASPADA
Peringatan dini, padahal belum ada serangan.

Perketat →

Sesudah: peluang ≈20%, kembali normal
Paparan dipotong 70%: 0,75 menjadi 0,225.

Kabar yang tidak menyangkut aset satuan menghasilkan peluang nol: tidak ada alarm palsu.

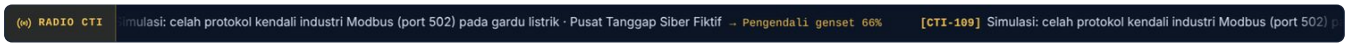
Rumus ini sengaja sederhana dan bisa diperiksa dengan kalkulator: 0,80 × 0,75 × 1,0 × 1,1 = 0,66.

Setelah Perketat: 0,80 × 0,225 × 1,0 × 1,1 ≈ 0,20.

Perhitungan peluang serangan per aset

Kini ada **sumber kedua**: AI lokal. Bila lalu lintas sebuah aset tidak wajar, AI memberi peluangnya sendiri, lalu keduanya digabung: **peluang gabungan = 1 − (1 − peluang CTI) × (1 − peluang AI)**. Artinya, dua petunjuk yang saling menguatkan menghasilkan peluang lebih tinggi daripada masing-masing. Penjelasan lengkapnya ada di subbab *AI lokal* di akhir bab ini.

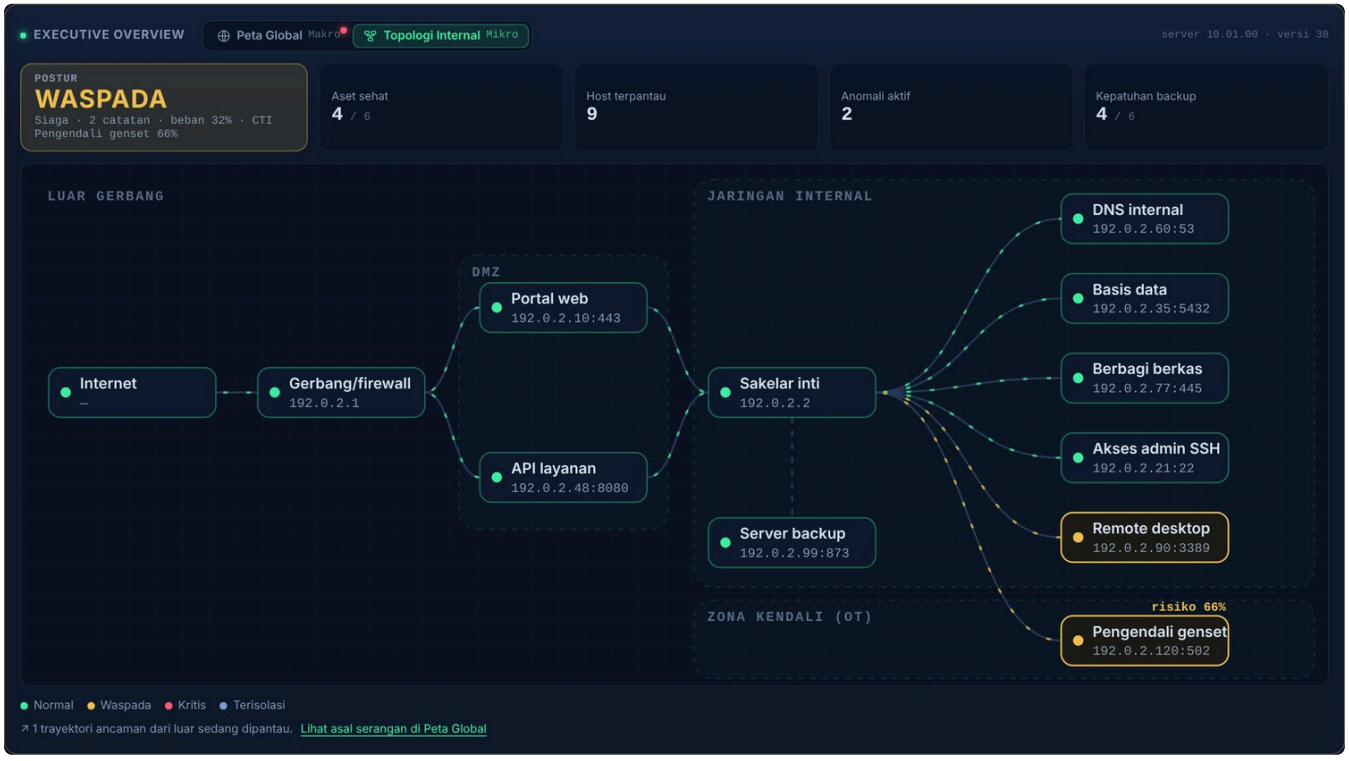
Seperti apa di layar



Radio CTI di dasbor menyiarkan kabar CTI-109 tentang celah protokol kendali industri Modbus. Panah di ujungnya menunjukkan aset yang terkena: pengendali genset 66%.



Panel Prediksi CTI (kini bernama Prediksi CTI + AI) menampilkan aset yang diprediksi diserang, lengkap dengan tombol Perketat. Gambar ini diambil sebelum AI lokal ditambahkan; tampilan barunya ada di subbab AI lokal di bawah.



Di topologi, pengendali genset berubah kuning dengan label "risiko 66%". Belum ada serangan; ini peringatan dini.



Setelah tombol Perketat ditekan, peluang turun ke 20% dan tercatat "diperketat (paparan −70%)".

Cara membaca Radar Anomali

Image — Konsep Radar Anomali dari Proposal

Gambar konsep dari Proposal. Jarak dari pusat menunjukkan zona jaringan (dalam, tengah, luar), bukan jarak geografis. Warna menunjukkan keparahan: hijau normal, kuning berisiko, merah ancaman, biru diblokir.

Image — Radar Anomali di dasbor saat genset WASPADA

Radar asli di dasbor: satu titik kuning berlingkar di cincin dalam adalah pengendali genset yang sedang WASPADA.

> **Kalimat siap pakai:** "Setiap hari ada ratusan kabar ancaman. Nusantara Shield hanya menaikkan aset yang benar-benar terkait. Contohnya, kabar celah Modbus langsung menaikkan genset rumah sakit ke WASPADA dengan peluang 66%, padahal belum ada serangan. Satu klik Perketat menurunkannya ke 20%."

AI lokal: mengenali lalu lintas yang tidak wajar

Kabar CTI hanya memperingatkan ancaman yang **sudah diumumkan** orang lain. Bagaimana dengan serangan yang belum pernah diberitakan? Untuk itu Nusantara Shield punya sumber kedua: **Engine Deteksi Anomali**, sebuah AI kecil yang berjalan di *server* satuan sendiri.

Analogi. Bayangkan satpam yang sudah berminggu-minggu hafal kebiasaan kantor: berapa tamu biasanya datang, jam berapa, dan ke ruangan mana. Suatu malam ada orang yang mencoba membuka pintu ruang *server* 24 kali. Satpam itu curiga, walaupun wajah orang itu tidak ada di daftar buronan. Itulah deteksi anomali: tidak mencari "wajah buronan" (*signature*), tetapi **perilaku yang menyimpang dari kebiasaan**.

Istilah kunci

- ***Machine learning***: komputer belajar pola dari contoh data, bukan dari aturan yang ditulis satu per satu.
- ***Isolation Forest***: algoritma yang kami pakai. Ia "memotong-motong" data secara acak. Data yang aneh cepat terpisah dari kerumunan, seperti satu orang berbaju merah di barisan berbaju hijau yang cukup ditemukan dengan sedikit pertanyaan.
- **Skor anomali**: angka 0 sampai 1. Lalu lintas wajar sekitar 0,39; di atas **0,58** dianggap tidak wajar.
- ***Explainability***: AI wajib menyebut alasannya dalam bahasa manusia, misalnya "perintah tulis Modbus 10× normal".
- ***Local inference*** dan ***air-gapped***: yang pertama berarti model dihitung di *server* sendiri, bukan lewat API di internet. Yang kedua berarti jaringannya sama sekali tidak tersambung ke internet. AI kami memenuhi yang pertama dan **siap** untuk yang kedua.

Apa yang diamati. Enam ciri lalu lintas tiap aset: jumlah koneksi, volume data, ragam *port* tujuan, *login* gagal, operasi tulis (untuk genset: perintah tulis Modbus), dan porsi koneksi ke luar jaringan. Model dilatih dari 1.500 contoh lalu lintas normal saat *server* menyala (sekitar 0,16 detik), lalu menilai 9 aset dalam sekitar 10 milidetik.

Bagaimana masuk ke peluang serangan. Skor di atas ambang diubah menjadi peluang AI, lalu digabung dengan peluang dari CTI seperti rumus di atas. Tombol **Perketat** tetap bisa menurunkannya.

Mencoba sendiri. Tekan **Latihan AI: suntik lalu lintas Modbus tak wajar (genset)** di panel Prediksi CTI + AI. Suntikan ini data sintetis dan berakhir sendiri setelah 5 menit.

Image — Panel Prediksi CTI + AI dalam keadaan normal

Keadaan normal. Baris kecil di bawah menunjukkan AI bekerja: Isolation Forest, 100 pohon, 6 ciri, luring, menilai 9 aset dalam sekitar 10 ms, semua lalu lintas wajar.

Image — Panel setelah Latihan AI: genset 88% dari sumber AI-ANOMALI

Setelah Latihan AI: pengendali genset muncul dengan sumber AI-ANOMALI, skor 0,67, alasan "perintah tulis Modbus 10× normal", dan peluang 88%. Belum ada kabar CTI tentang genset. (Akses admin SSH 39% berasal dari kabar CTI lain yang kebetulan masuk.)

Image — Topologi: pengendali genset kuning, risiko 88%

Di topologi, pengendali genset di zona kendali (OT) berubah kuning dengan label "risiko 88%", dan kotak Postur menyebut sumbernya: AI. Aset kantor lain tetap hijau.

Image — Log mencatat temuan AI lokal

Log mencatat temuan dengan label AI, lengkap dengan skor dan alasannya. Jejak ini ikut masuk log audit.

Image — Panel setelah kabar CTI-109 masuk: genset 96%

Lalu kabar CTI-109 (celah Modbus) masuk. Dua petunjuk digabung, sehingga peluang genset naik dari 88% ke 96%.

Image — Panel setelah Perketat: genset 41%

Setelah Perketat: peluang turun ke 41%, di bawah ambang 50%, sehingga genset kembali normal.

Batas wewenang dan batas purwarupa

- AI hanya **menaikkan status** ke WASPADA dan mencatat di *log*. Ia tidak pernah memutus jaringan; yang menahan tombol tetap operator (*human-in-the-loop*).
- Ciri lalu lintas di purwarupa masih **sintetis**. Di lapangan, ciri yang sama diambil dari sensor jaringan seperti Zeek atau Suricata, lalu model dilatih ulang dari lalu lintas normal satuan itu sendiri.
- **Engine Asisten Narasi** (model bahasa seperti Llama 3 8B lewat Ollama) untuk menyusun draf LAPSIT **belum ada**; itu peta jalan. Model berat sengaja tidak dimasukkan ke *server* inti agar CPU tetap hemat.

> **Kalimat siap pakai:** "Kabar CTI memberi tahu kami ancaman yang sudah dikenal. Untuk yang belum dikenal, AI lokal kami menghafal lalu lintas normal dan menandai yang menyimpang, misalnya perintah tulis Modbus sepuluh kali lipat dari biasanya. Ia berjalan di *server* satuan tanpa internet, selalu menyebut alasannya, dan tidak pernah memutus jaringan sendiri. Keputusan tetap di tangan operator."

Triase dan Nilai Kesiapan Siber

Dua fitur ini menjawab dua pertanyaan yang paling sering muncul di posko. Pimpinan bertanya **"seberapa siap kita sekarang?"**; operator bertanya **"alarm ini benar atau tidak?"**

Nilai Kesiapan Siber (rapor A–E). Di samping kotak Postur ada kartu berisi satu huruf, mirip rapor sekolah. Huruf itu gabungan dua sub-skor 0–100:

- **Kerawanan**: seberapa terbuka layanan sebelum diserang. Turun bila ada kabar ancaman atau anomali AI yang mengenai asetnya, ada temuan konfigurasi (misalnya akses RDP terbuka), atau backup terlambat atau belum diuji.
- **Insiden**: seberapa genting keadaan saat ini. Turun banyak bila ada insiden yang belum ditahan, lebih sedikit bila sudah ditahan, dan sedikit lagi untuk setiap peringatan WASPADA yang belum ditangani.

Nilai yang dipakai adalah **yang lebih rendah** dari keduanya, karena rantai sekuat mata rantai terlemah. Selama ada insiden yang belum ditahan, nilai posko paling tinggi D. Deretan huruf kecil di bawahnya adalah nilai tiap layanan; arahkan tetikus ke kartu untuk melihat rinciannya. Rumus lengkapnya terbuka di Dokumentasi Teknis §2.5.

Triase: menutup peringatan dengan alasan. Tidak semua alarm benar. Setiap aset berstatus WASPADA punya tombol **Tutup peringatan**, khusus Operator. Operator memilih salah satu:

- **Selesai ditangani**: ancamannya sudah ditindak, misalnya akses sudah ditutup manual.
- **Positif Palsu (*False Positive*)**: alarm ternyata bukan ancaman, misalnya *port* yang disebut berita ternyata hanya terbuka ke jaringan dalam.

Alasan tertulis wajib, minimal 15 karakter. Analoginya buku piket satpam: alarm boleh dimatikan, tetapi petugas wajib menulis siapa, kapan, dan mengapa. **Tidak ada yang dihapus.** Penutupan menjadi halaman baru di Buku Rantai Bukti, dan bila ada bukti baru (berita lain atau anomali AI berikutnya), peringatan terbuka lagi. Jumlah *False Positive* dihitung terpisah sebagai bahan evaluasi untuk menyetel ambang CTI dan AI.

> **Kalimat siap pakai:** "Operator boleh menyatakan sebuah alarm *False Positive*, tetapi tidak bisa menghapusnya diam-diam. Setiap penutupan beralasan dan tercatat di buku berantai yang sama dengan barang bukti."

Aturan deteksi: menghitung, bukan menebak

AI menilai **pola** lalu lintas. Aturan deteksi bekerja lebih sederhana: ia **menghitung** peristiwa mentah, persis seperti satpam yang mencatat berapa kali seseorang salah memasukkan kode pintu. Di *server*, berkas `app/deteksi.py` membaca setiap percobaan *login* dan setiap koneksi masuk, lalu memeriksa tiga aturan yang ambangnya tertulis terbuka:

Aturan	Kapan menyala	Keparahan
***Login* gagal berulang**	8 kali gagal dari satu alamat dalam 60 detik	Sedang
***Login* tembus**	*Login* berhasil dari alamat yang sama paling lama 120 detik sesudah rentetan gagal itu	Tinggi
Pemindaian *port*	Satu alamat mencoba 15 "pintu" (kombinasi aset dan *port*) berbeda dalam 10 detik	Tinggi

Temuan tetap aktif 5 menit sejak peristiwa terakhirnya. Aturannya sama dengan kabar ancaman dan AI: temuan **hanya menaikkan aset ke WASPADA**, tidak pernah memutus jaringan. Perketat memotong sumbangannya, dan triase dapat menutupnya dengan alasan. Di panel Latihan ada dua tombol, **Login gagal berulang** dan **Pemindaian port**, yang memutar peristiwa sintetis supaya juri bisa melihat aturan ini bekerja.

Hasilnya muncul di tabel **Peringatan terbaru** selebar layar di bawah baris Radar, Aset, dan Beban Jaringan: satu baris per peringatan, berisi keparahan, aset, status, dan waktu. Labelnya diambil dari data yang tercatat, misalnya "Diisolasi oleh operator · bukti BB-2026-001": nama Operator dan nomor berita acara bukti yang sebenarnya, bukan teks tetap.

> **Kalimat siap pakai:** "Aturan deteksi kami tidak menebak. Delapan *login* gagal dalam enam puluh detik, baru menyala; tujuh, belum. Ambangnya tertulis di kode dan dikunci uji, jadi juri bisa memeriksanya sendiri."

Aturan OT, label MITRE ATT&CK, dan label sumber data

Sejak 27 Oktober 2026, Engine Deteksi Aturan juga menjaga zona kendali OT (pengendali genset, Modbus/TCP). Tiga aturan baru ini deterministik: tidak menebak, dan ambangnya tertulis terbuka di `app/deteksi.py`.

Aturan	Kapan menyala	Keparahan
Koneksi OT tanpa izin	Alamat di luar daftar jalur OT yang diizinkan (di purwarupa hanya stasiun rekayasa 192.0.2.140) membuka koneksi Modbus ke pengendali genset	Tinggi
Perintah tulis di luar jadwal	Perintah tulis Modbus (fungsi 5, 6, 15, 16) di luar jendela pemeliharaan 22.00–02.00	Kritis
Rantai IT ke OT	Koneksi tanpa izin disusul perintah tulis di luar jadwal dari alamat yang sama dalam 10 menit	Kritis

Aturannya tetap dua kunci: temuan OT **hanya menaikkan genset ke WASPADA**. Memutus jalur tetap menunggu Operator menahan tombol, dan bukti tetap diamankan lebih dulu. Tombol latihan baru, **Akses OT tanpa izin**, memutar peristiwa sintetis supaya juri bisa melihat ketiga aturan menyala berurutan.

Peringatan dari aturan deteksi dan skenario latihan kini membawa **label MITRE ATT&CK**, kamus teknik serangan yang dipakai pusat operasi keamanan (SOC) di banyak negara. Contohnya: login gagal berulang = T1110 *Brute Force*, login tembus = T1078 *Valid Accounts*, pemindaian port = T1046 *Network Service Discovery*, dan aturan OT memakai matriks ATT&CK for ICS (T0886 *Remote Services*, T0855 *Unauthorized Command Message*). Gunanya: laporan kita memakai bahasa yang sama dengan Kartika CSIRT dan tim siber lain. Peringatan AI lokal sengaja tanpa label, karena AI menilai perilaku yang tidak wajar, bukan satu teknik tertentu; memberi label di situ sama dengan menebak.

Di bawah setiap peringatan juga ada **label sumber data**, supaya tidak ada yang mengira data latihan sebagai serangan sungguhan. Misalnya "Sumber: peristiwa latihan sintetis · aturan deteksi berjalan nyata" atau "Sumber: log impor «auth.log» dari Operator · aturan deteksi berjalan nyata".

LAPSIT ikut berubah: bagian **3. Peringatan terbaru** mencantumkan label ATT&CK tiap peringatan, dan bagian **5. Pengesahan** menyediakan dua tanda tangan, Operator jaga sebagai pembuat laporan dan pejabat yang mengetahui, supaya laporan siap diteruskan berjenjang.

Impor log luring: aturan yang sama untuk log asli

Tombol **Impor log…** (hanya Operator) membaca berkas log yang dibawa dari *server* sendiri, tanpa internet. Tiga format dikenali otomatis: log autentikasi OpenSSH (`auth.log`), log firewall UFW/iptables, dan CSV berkepala `waktu,jenis,sumber,…`. Tidak ada aturan khusus untuk log impor: aturan yang menilai data latihan juga menilai log asli.

Batas dan pengamannya:

- Ukuran sampai ±2 MB dan 50.000 baris. Jalur lain tetap dibatasi 16 KB, dan kiriman besar tanpa token ditolak sebelum dibaca.
- Baris yang tidak sah (alamat IP, port, atau waktu yang keliru) dilewati dan dihitung, bukan ditebak.
- Nama akun dalam log tidak disalin. Log audit hanya mencatat nama berkas dan jumlah barisnya, bukan isinya.
- Dua kunci tetap utuh: temuan dari log impor hanya menaikkan aset ke WASPADA, tanpa membuat insiden, bukti, atau isolasi.

Contoh berkas ada di folder `docs/contoh-log/`. Isinya rekaan dengan alamat khusus dokumentasi (192.0.2.x dan 203.0.113.x), bukan log satuan sungguhan, jadi jangan menyebutnya "data serangan nyata".

> **Kalimat siap pakai:** "Bukan hanya data latihan. Bawa auth.log dari *server* Bapak, dan aturan yang sama menilainya tanpa internet, tanpa menyalin nama akun, dan tanpa pernah memutus jaringan sendiri."

Linimasa 60 menit dan KPI posko

Posko dijaga 24 jam, jadi petugas jaga berikutnya perlu tahu **apa yang terjadi satu jam terakhir**. Di panel Beban Jaringan kini ada **linimasa 60 menit**: setiap batang adalah rata-rata beban satu menit. Saat posko baru dibuka, 60 menit sebelumnya diisi **data latihan**

(batang redup), dan labelnya tertulis jelas. Setiap menit, satu batang baru dari beban posko yang sebenarnya menggeser data latihan itu; menit yang memuat insiden diberi tanda merah di atasnya.

Di bawahnya ada **pita anomali AI per aset**: nama aset, berapa menit lalu lintasnya tidak wajar, dan alasan dari model. Klik pita untuk menyorot aset itu di Topologi Internal.

Dua angka baru di kotak KPI:

- **Waktu respons (MTTC)**: rata-rata waktu dari insiden dimulai sampai ancaman ditahan.
- **Insiden sejak posko aktif**: jumlah insiden latihan sejak posko dibuka.

Keduanya dihitung dari kejadian yang tercatat, bukan angka tetap.

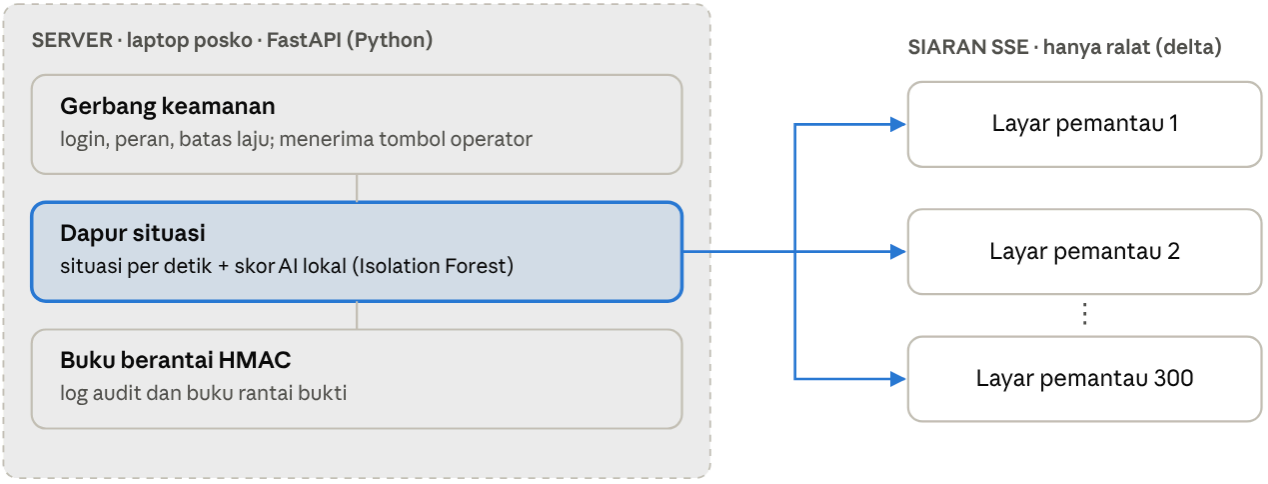
Bab 8 — Di Balik Layar: Dapur, Siaran, dan 310 Uji

Bab ini cukup dipahami garis besarnya. Juri teknis biasanya bertanya dua hal: **bagaimana sistem tetap ringan bila banyak orang memantau sekaligus**, dan **bagaimana kami tahu sistemnya benar**. Jawabannya: satu dapur dengan siaran ralat, dan 310 uji otomatis.

Istilah kunci

- ***Server***: komputer pusat yang menjalankan Nusantara Shield. Di purwarupa cukup satu laptop. Aplikasi, dokumen lomba, dan buku-buku Onno W. Purbo memakai kata "*server*", jadi pakailah kata itu di depan juri.
- **FastAPI:** kerangka kerja berbahasa Python untuk membangun "loket" layanan. Setiap loket menerima satu jenis permintaan, misalnya login atau tombol isolasi.
- **API:** deretan loket tadi; cara layar dan server saling meminta dan memberi data.
- **Peramban** (*browser*): aplikasi seperti Chrome atau Firefox. Dasbor tampil di sini, ditulis dengan JavaScript polos (*Vanilla JS*) dan Canvas untuk menggambar.
- **SSE** (*Server-Sent Events*): siaran satu arah dari server ke layar. Analoginya radio: pemancar bicara, semua pesawat radio mendengar, tanpa perlu bertanya terus.
- **Ralat (delta):** hanya bagian yang berubah yang dikirim. Analoginya koran yang memuat ralat satu baris, bukan mencetak ulang satu koran utuh.

Satu dapur memasak, semua layar hanya menerima ralat



Uji beban 300 layar serentak: CPU server 10,8% → 2,8%, lalu lintas 8,4 → 1,7 MB/s (−80%).
Layar memakai JavaScript polos dan Canvas: tanpa pustaka luar, tanpa CDN.

Arsitektur: satu server, banyak layar

Satu dapur, satu pengeras suara

Bayangkan 300 prajurit masing-masing memasak sendiri: boros kompor dan bahan. Jauh lebih hemat bila ada **satu dapur umum** yang memasak, lalu makanannya dibagikan. Nusantara Shield bekerja begitu: *server* menghitung gambaran situasi **sekali per detik**, lalu menyiarkan ralatnya ke semua layar.

Beban versi akhir (diukur 26 Oktober 2026). Alat ukurnya ikut di repositori, `tools/ukur_beban.py`, sehingga siapa pun bisa mengulangnya: alat itu menyalakan *server*, membuka 300 siaran sungguhan, lalu mencatat kerja prosesor *server* selama 60 detik (mesin Linux 2 inti).

Ukuran (300 layar serentak)	Siaga	Saat serangan
Beban CPU server	**±1,5%**	**±1,7%**
Memori server, termasuk pustaka AI	±207 MB	±207 MB

Riwayat optimasi (uji beban 17 Oktober 2026, alat dan mesin lain). Siaran ralat menurunkan CPU dari 10,8% ke 2,8% dan lalu lintas saat serangan intensif dari 8,4 ke **1,7 MB/s (−80%)**. Jangan membandingkan 2,8% dengan 1,5% seolah sistemnya makin hemat: alat ukurnya berbeda. Yang benar: "versi akhir kami ukur ulang, hasilnya ±1,5%."

Image — Panel Beban Jaringan di dasbor

Panel Beban Jaringan di dasbor: persentase beban dan ambang aman/waspada/kritis. Tangkapan ini dari versi sebelumnya; kini grafik 48 detik di bawahnya diganti linimasa 60 menit dan pita anomali AI per aset, sedangkan Peringatan terbaru menjadi tabel tersendiri di bawahnya (Bab 7).

310 uji otomatis

Uji otomatis adalah daftar periksa yang dijalankan komputer, mirip daftar periksa pilot sebelum terbang. Setiap uji mencoba satu perilaku, misalnya "isolasi tanpa bukti harus ditolak", lalu memastikan hasilnya benar. Alatnya bernama **pytest**. Bila satu aturan dilanggar, uji gagal dan ketahuan sebelum sampai ke pengguna.

Yang istimewa: uji ini mengunci **aturan doktrin**, bukan sekadar fungsi. Contohnya: isolasi tanpa bukti ditolak 409; pemulihan terkunci bila sidik jari berbeda; sabotase OT diputus tanpa mematikan genset; kata sandi tidak pernah tercatat di *log*.

Ada **10 uji khusus AI**, **24 uji Engine Deteksi Aturan**, **23 uji aturan OT, label MITRE ATT&CK, dan pengesahan LAPSIT**, **18 uji impor log luring**, dan **6 uji linimasa dan KPI**. Uji deteksi mengunci ambangnya sampai ke hitungan: gagal ketujuh belum menyala, gagal kedelapan menyala. Uji OT memastikan perintah tulis di dalam jendela pemeliharaan tidak memicu alarm. Ada pula 12 uji verifikasi audit tanpa server: setiap jenis coretan pada log harus tertangkap beserta nomor entrinya. Salah satu uji AI memblokir semua koneksi jaringan, lalu memastikan model tetap bisa dilatih dan menilai. Uji lain memastikan lalu lintas wajar tidak memicu alarm palsu, dan bahwa AI maupun aturan hanya menaikkan status tanpa pernah memutus jaringan.

Image — Slide 4 dek: hasil 204 uji lulus dalam 10 kelompok

Slide 4 dek presentasi: beban CPU turun 74% karena siaran ralat, dan seluruh uji lulus. Tangkapan ini diambil saat jumlah uji masih 204; kini 310 uji dalam 16 kelompok (termasuk 10 uji AI lokal, 24 uji Engine Deteksi Aturan, 23 uji aturan OT, label MITRE ATT&CK, dan pengesahan LAPSIT, 18 uji impor log luring, 12 uji verifikasi audit tanpa server, 6 uji linimasa dan KPI, 8 uji paket pasang luring, dan 16 uji triase), lulus dalam sekitar satu menit tergantung komputernya.

> **Kalimat siap pakai:** "Satu dapur, satu pengeras suara: server memasak gambaran situasi sekali per detik dan hanya menyiarkan ralatnya. Untuk 300 layar, beban CPU sekitar satu setengah persen. Semua aturan doktrin dikunci 310 uji otomatis, dan semuanya lulus."

Bab 9 — Menjaga Sistem Itu Sendiri

Alat pertahanan yang mudah dibobol justru menjadi pintu masuk baru. Karena itu Nusantara Shield sendiri dijaga berlapis: setiap tombol yang ditekan harus lolos **enam gerbang pemeriksaan** di server, dan seluruh sistem bisa berjalan **tanpa internet sama sekali**.

Istilah kunci

- **Autentikasi (login):** membuktikan siapa Anda dengan nama akun dan kata sandi (minimal 12 karakter). Kata sandi tidak pernah ditulis ke catatan mana pun.
- **Token:** kartu tanda masuk sementara yang diberikan setelah login. Seperti kartu tamu di pos jaga: berlaku terbatas, lalu kedaluwarsa.
- **Otorisasi (peran):** menentukan apa yang boleh Anda lakukan. **Pengamat** hanya melihat; **Operator** boleh bertindak. Akun operator hanya bisa dibuat lewat kode undangan atau oleh operator lain.
- **Batas laju** (*rate limit*): membatasi berapa kali seseorang boleh mencoba dalam waktu tertentu. Mencegah penyerang menebak kata sandi berkali-kali.
- **Log audit:** buku harian sistem yang mencatat siapa melakukan apa, kapan, dan alasannya. Dirantai dengan HMAC (Bab 5), sehingga tidak bisa diubah diam-diam.



Enam gerbang pemeriksaan di server

Image — Panel Log di dasbor: catatan IR dan tindakan SOAR

Panel Log di dasbor: setiap tindakan tercatat dengan jam, jenisnya (IR, SOAR), dan uraiannya.

Bila kelak tersambung ke perangkat nyata

Purwarupa belum memegang kata sandi atau kunci perangkat lain, karena pemutusan masih simulasi. Begitu tersambung ke *firewall*, sakelar, atau Active Directory sungguhan, Nusantara Shield akan memegang "kunci gudang" seluruh jaringan. Karena itu empat aturan wajib dipasang lebih dulu:

- **Brankas kredensial:** kunci perangkat disimpan di brankas khusus, bukan di berkas pengaturan.
- **Hak minimum:** setiap *playbook* hanya boleh menyentuh perangkat yang memang diperlukannya.
- ***Playbook* bertanda tangan:** isi *playbook* tidak bisa diubah diam-diam.
- **Aturan dua orang:** perubahan *playbook* harus disetujui dua orang.

Batas lain yang perlu Bapak akui dengan jujur bila ditanya: belum ada verifikasi dua langkah, belum ada uji penetrasi oleh pihak independen, dan HTTPS baru dipasang lewat *proxy* balik saat penerapan. Rinciannya ada di Dokumentasi Teknis §2.7.

Mode Berdaulat: berjalan tanpa internet

Kedaulatan di sini berarti seluruh data dan proses tetap berada di dalam jaringan satuan. Istilah yang sering dipakai:

- **Luring** (*offline*): berjalan tanpa sambungan internet.
- ***On-premise*****:** dipasang di perangkat milik sendiri, bukan disewa dari layanan awan.
- ***Air-gapped*****:** jaringan yang secara fisik tidak tersambung ke internet sama sekali. Lazim di lingkungan militer.
- **CDN** (*Content Delivery Network*): layanan luar yang biasa dipakai situs web untuk memuat huruf atau skrip. Nusantara Shield **tidak memakainya**, sehingga tidak ada satu pun permintaan keluar dari layar.

Internet hanya dibutuhkan sekali, saat memasang bahan-bahannya (`pip install`). Setelah itu kabel internet boleh dicabut dan dasbor tetap berjalan penuh.

AI lokal juga berdaulat. Model deteksi anomali dilatih dan dihitung di laptop posko itu sendiri (*local inference*). Tidak ada model yang diunduh dan tidak ada API di internet yang dipanggil, sehingga AI tetap bekerja saat kabel internet dicabut. Karena itu ia **siap** dipasang di jaringan *air-gapped*.

Bahkan tanpa internet sama sekali. Untuk posko *air-gapped*, kode dan seluruh pustaka dikemas menjadi satu **paket pasang luring** beserta daftar sidik jari SHA-256. Analoginya seperti peti logistik bersegel: sebelum dibuka, segel dan daftar isinya dicocokkan dengan berita acara serah terima. Satu berkas saja berbeda, pemasangan dihentikan. Setelah itu pustaka dipasang hanya dari isi peti (`pip install --no-index`), dan uji otomatis dijalankan sebagai bukti pemasangan utuh.

Image — Mode Berdaulat: berjalan luring penuh di dalam jaringan tertutup satuan

Gambar dari Proposal: semua bagian berada di dalam jaringan tertutup satuan; layanan awan dan fon eksternal tidak dipakai.

Mode Hybrid (sambungan terkendali untuk menerima kabar ancaman resmi dari BSSN atau MISP) adalah **rencana lanjutan dan belum ada di purwarupa**. Sebutkan ini dengan jujur bila ditanya.

> **Kalimat siap pakai:** "Alat pertahanan tidak boleh menjadi pintu masuk baru. Setiap tombol diperiksa enam gerbang di server, dan seluruh sistem berjalan luring di laptop posko. Cabut internetnya, dasbor tetap berjalan."

Selaras dengan NIST CSF 2.0

NIST *Cybersecurity Framework* (CSF) 2.0 adalah kerangka yang lazim dipakai untuk menilai apakah sebuah program keamanan siber sudah lengkap. Ia membagi pekerjaan ke enam fungsi, seperti daftar periksa kesiapan pos jaga.

Fungsi	Artinya	Contoh di Nusantara Shield
Govern	Siapa berwenang atas apa	Pengamat dan Operator; dua kunci konfirmasi
Identify	Tahu apa yang dijaga dan risikonya	Inventaris aset IT dan OT; peluang serangan per aset
Protect	Memperkecil celah	Perketat, kepatuhan backup, akses posko berlapis
Detect	Melihat ancaman	AI lokal, aturan login gagal berulang dan pemindaian port, radar, triase peringatan
Respond	Menanggapi insiden	Bukti dulu, isolasi ±1,2 detik, LAPSIT
Recover	Kembali normal tanpa merusak bukti	Pemulihan terkunci sampai sidik jari cocok

Rincian per kategori dan uji yang membuktikannya ada di Dokumentasi Teknis §2.6. Ingat: ini **pemetaan mandiri**, bukan sertifikasi. Jangan katakan "kami tersertifikasi NIST".

Lisensi: GNU GPL v3.0

Kode Nusantara Shield dirilis di bawah **GNU General Public License v3.0** (berkas `LICENSE` di repositori), dan setiap berkas kode membawa header SPDX `GPL-3.0-only`. Artinya siapa pun boleh memakai, mempelajari, mengubah, dan membagikannya, asal turunannya tetap terbuka dengan lisensi yang sama. Karena itu kami **tidak** menulis "All rights reserved": kalimat itu bertentangan dengan lisensi terbuka.

> **Kalimat siap pakai:** "Kami memilih GPLv3 supaya alat pertahanan ini bisa diaudit siapa pun, dan turunannya tidak bisa ditutup."

Bab 10 — Latihan Menjelaskan

Memahami saja belum cukup; yang dinilai juri adalah **cara Bapak menyampaikannya**. Bab ini berisi tiga versi penjelasan, alur demo bergambar, dan jawaban untuk pertanyaan yang paling mungkin muncul.

Versi 30 detik (lift pitch)

> "Juni 2024, PDNS lumpuh. Penyusupnya sudah terlihat dua hari sebelumnya, tetapi tidak ada yang bertindak. Nusantara Shield menutup celah itu: perisai pertahanan siber luring yang mendeteksi, mencegah, dan membantu merespons; ia memperingatkan lebih dulu, memutus dalam 1,2 detik, dan tidak pernah menghapus barang bukti. Kabar ancaman dan AI lokal menaikkan aset berisiko, termasuk genset rumah sakit, ke WASPADA sebelum diserang, dan satu klik Perketat menurunkan risikonya. Bila serangan tetap tembus, satu tombol menyegel bukti lalu memutus jalur penyerang tanpa mematikan genset. Semuanya luring dan dikunci 310 uji otomatis."

Versi 2 menit: empat babak

Struktur cerita dua menit

Image — Slide 1 dek: Latar Belakang dan Urgensi

Babak 1 memakai Slide 1 dek: sejarah BSI dan PDNS di kiri, pertanyaan proyeksi rumah sakit di bawahnya.

Image — Slide 3 dek: Tangkal lebih dulu; bila tembus, bukti dulu baru putus

Babak 2 memakai Slide 3: siklus OODA di kiri, dan di kanan lima langkah yang dibuka dengan Tangkal (peringatan dini dan Perketat), baru kemudian bukti, isolasi, LAPSIT, dan pemulihan.

Alur demo bergambar: *ransomware* di SIMRS

1. **Masuk sebagai operator.** Tunjukkan topologi dan radar: semua hijau.
2. **Latihan → target RS Kesdam → Ransomware.** Postur langsung KRITIS.

Image — Topologi saat ransomware menyerang SIMRS: postur KRITIS, beberapa aset merah

Serangan dimulai: postur KRITIS; Berbagi berkas dan Server backup menyala merah, dan server kendali penyerang (203.0.113.45) muncul merah di Luar Gerbang.

3. **Tahan tombol ⚡ EKSEKUSI ISOLASI selama 0,6 detik.** Katakan: "Perhatikan, bukti disegel dulu."

Image — Action Center setelah isolasi ransomware: bukti BB-2026-004 disegel, TERISOLASI…

Action Center: bukti BB-2026-004 disegel SHA-256, status TERISOLASI, LAPSIT IR-2026-004 terkirim ke Dansat dan Kasi Siber.

4. **Tunjukkan topologi:** aset terdampak kini bergaris putus-putus (terisolasi).

Image — Topologi setelah isolasi ransomware: aset terdampak terisolasi

Setelah isolasi: Berbagi berkas, Server backup, dan server kendali penyerang kini biru bergaris putus-putus (terisolasi atau diblokir). Aset lain tetap kuning (waspada) sampai insiden ditutup.

5. **Coba tekan Pulihkan.** Tombol menolak: langkah *playbook* belum dicentang dan sidik jari bukti harus dicocokkan ulang dulu. Katakan: "Pemulihan pun tidak boleh menghapus jejak."

Pertanyaan juri yang paling mungkin

Pertanyaan	Jawaban singkat
Apakah sudah tersambung ke sakelar dan genset sungguhan?	Belum. Perintah ke sakelar masih simulasi *webhook*, dan semua data sintetis. Sensor protokol industri dan sakelar fisik adalah peta jalan berikutnya.
Kenapa rumah sakit?	TNI AD punya aset kesehatan vital (RSPAD, rumah sakit jajaran Kesdam). Di sana IT dan OT bertemu dan menyangkut nyawa. Kasus Winnipeg 2026 membuktikan *ransomware* sudah menyasar OT rumah sakit.

Pertanyaan	Jawaban singkat
Bagaimana jika alat forensik gagal?	Ada Isolasi Darurat: alasan tertulis minimal 15 karakter, tahan tombol 1,5 detik, tercatat di tiga tempat. Pemulihan tetap terkunci sampai bukti susulan aman.
Datanya dari mana?	Sintetis. Alamat IP memakai blok dokumentasi resmi RFC 5737; nama orang dan satuan fiktif.
Apakah memakai AI?	**Ya, untuk deteksi anomali.** Model *machine learning* ringan (*Isolation Forest*, scikit-learn) dilatih dan dijalankan di *server* satuan. Lalu lintas yang tidak wajar menaikkan aset ke WASPADA dengan alasan yang bisa dibaca, misalnya "perintah tulis Modbus 10× normal". Ini *local inference*: tanpa API luar, sehingga siap dipasang di jaringan *air-gapped*. AI hanya menaikkan status; memutus jaringan tetap keputusan operator. Model bahasa (Llama 3 8B lewat Ollama) untuk menyusun draf LAPSIT masih peta jalan. Selain itu, asisten AI dipakai pengembang saat menulis kode, sebagaimana diizinkan panitia.
Bagaimana kalau ribuan layar?	Saat ini satu proses server, teruji 300 layar dengan CPU ±1,5% (±1,7% saat serangan), diukur ulang pada versi akhir. Operasi multiproses adalah langkah lanjutan.
Kenapa tidak isolasi otomatis saja?	Untuk aset vital, dua kunci disengaja: peringatan keliru tidak boleh memutus SIMRS atau genset. Peta jalannya **respons bertingkat menurut kritikalitas aset**: endpoint kantor berisiko rendah boleh diisolasi otomatis berdasarkan playbook praotorisasi, tetap dengan bukti dulu dan tercatat di LAPSIT.
Bisakah dipakai untuk menyerang?	Tidak. Nusantara Shield murni defensif: mengamati, menyegel bukti, memutus, melapor, dan memulihkan.

Kata yang sebaiknya dihindari

- "100% aman" atau "tidak bisa diretas". Tidak ada sistem seperti itu; juri akan langsung curiga.
- "Sudah mengendalikan genset sungguhan." Belum; itu simulasi.
- "Otonom penuh" atau "fully autonomous". Nusantara Shield sengaja menjadi sistem pendukung keputusan: mesin mempercepat, manusia memutuskan.
- "Tersertifikasi NIST". Yang benar: fiturnya dipetakan ke NIST CSF 2.0 oleh tim sendiri.
- "AI yang memutuskan." AI di Nusantara Shield hanya menaikkan status dan menyebut alasannya; yang memutus jaringan selalu operator. Hindari juga "sistem kami sudah memakai LLM": model bahasa untuk draf LAPSIT masih peta jalan.

> **Kalimat siap pakai untuk menutup:** "Kami tidak mengklaim sistem ini sempurna. Yang kami tunjukkan adalah doktrin yang dikunci mesin: bukti dulu, baru putus, pulihkan tanpa menghapus jejak. Dan semuanya bisa diperiksa, dari 310 uji sampai rumus peluangnya."

Bab 11 — Konsep Penempatan: Di Mana dan Oleh Siapa

Jawaban singkatnya: **Nusantara Shield dipasang di posko siber (SOC) tiap satuan yang punya aset vital, dengan satu server luring per satuan, dan dioperasikan oleh tim siber yang sudah ada dalam struktur TNI AD.** Laporannya naik ke Kartika CSIRT di Pussiberad. Bab ini adalah **usulan konsep tim**, disusun dari struktur yang diberitakan resmi, dan belum diuji di lingkungan TNI AD.

Pertanyaan ini penting karena salah satu kriteria penilaian resmi adalah **Kelayakan Implementasi (15%)**: "potensi pengembangan lanjutan dan kemudahan penerapan di lingkungan satuan".

Fakta organisasi yang menjadi pijakan

Unsur	Yang diketahui dari sumber resmi	Sumber
Pussiberad (Pusat Siber TNI AD)	Penyelenggara utama lomba ini; sebelumnya bernama Pussansiad. Komandannya Brigjen TNI Dr. Fransiscus Ari Susetio, S.E., M.Han.	Syarat dan Ketentuan, CODEPOLITAN, Indonesiadefense

Unsur	Yang diketahui dari sumber resmi	Sumber
Kartika CSIRT	Tim tanggap insiden siber TNI AD, dibentuk berdasarkan Kep Kasad KEP/711/VIII/2020. Melayani seluruh unit organisasi TNI AD: mendeteksi, merespons, dan memulihkan insiden.	Profil Kartika CSIRT
Sansidam (Satuan Sandi dan Siber Kodam)	Unit siber di tingkat Kodam. Contohnya Sansidam Jaya, yang memiliki **Tim Penangkalan Siber**, nama yang sama dengan kategori lomba kita.	News FIN
Bintara Siber TNI AD	Rekrutmen khusus lulusan TI/siber tahun 2026; penempatan di bawah Pussiberad. Calon pengisi kursi operator.	News FIN
IIV TNI AD	Syarat dan Ketentuan pasal 14.3 menyebut pengamanan **Infrastruktur Informasi Vital (IIV) TNI AD** sebagai tujuan adopsi karya. Rumah sakit TNI AD termasuk aset yang layak diperlakukan sebagai IIV.	Syarat dan Ketentuan v1.1

Tambahan dari webinar pembukaan (19 Oktober 2026). Danpussiberad menyampaikan bahwa Pussiberad memiliki **empat satuan pelaksana (Satlak)** yang sejalan dengan empat kategori lomba: penindakan, penangkalan, siber sosial, dan dukungan teknologi. Jadi "pemilik" alami Nusantara Shield di tingkat pusat adalah **satuan pelaksana penangkalan Pussiberad**, bersama Kartika CSIRT. Beliau juga menyebut seleksi khusus Bintara Siber terakhir hanya mengisi 43 dari 50 kursi. Artinya tenaga siber masih langka, sehingga alat yang mudah dioperasikan menjadi nilai tambah.

SOC atau *war room*?

Keduanya, dengan peran berbeda. Rumah utamanya adalah SOC; *war room* memakai tampilan ringkasnya saat krisis.

	SOC / posko siber satuan	*War room* / ruang komando
Fungsi	Pemantauan rutin dan penanganan insiden	Pengambilan keputusan komando saat krisis
Waktu	Setiap hari, 24 jam bergiliran	Hanya saat insiden besar
Siapa	Operator jaga dan Kasi Siber	Dansat, staf, perwira siber
Yang dipakai	Seluruh dasbor: topologi, radar, Action Center, tombol isolasi	Executive Overview, Peta Global, dan LAPSIT dengan akun **Pengamat** (hanya melihat)

Usulan konsep penempatan tiga tingkat

Siapa melakukan apa

Pihak	Peran di Nusantara Shield	Tugas	Status di purwarupa
Dansat / Karumkit	Pengamat	Menerima LAPSIT, memantau postur	Ada: LAPSIT terkirim ke Dansat dan Kasi Siber
Kasi Siber / perwira siber satuan	Operator penanggung jawab	Menetapkan *playbook* praotorisasi, menulis alasan isolasi darurat, mengelola akun	Ada
Operator jaga (petugas TI rumah sakit atau Bintara Siber)	Operator	Memantau bergiliran, menahan tombol isolasi	Peran ada; jadwal piket adalah usulan
Teknisi fasilitas rumah sakit	Bukan pengguna dasbor	Cek fisik genset (langkah 5 *playbook*)	Usulan prosedur
Sansidam, Tim Penangkalan Siber	Pendamping atau cadangan operator	Membantu bila operator satuan kewalahan; meneruskan laporan	Usulan; akses lintas satuan belum dibangun

Pihak	Peran di Nusantara Shield	Tugas	Status di purwarupa
Kartika CSIRT, Pussiberad	Penerima laporan	Menganalisis berita acara bukti; menyebarkan kabar ancaman baru	Usulan; di purwarupa LAPSIT bisa diekspor PDF dan diserahkan manual

Kebutuhan minimum di satu satuan

- **Perangkat:** satu laptop atau PC sebagai server (2 inti, 512 MB memori bebas, Python 3.10), tersambung ke jaringan internal rumah sakit.
- **Tempat:** ruang server atau posko siber; layar kedua opsional di ruang komando.
- **Akun:** minimal dua Operator (agar ada pengganti) dan satu Pengamat untuk Dansat.
- **Kunci:** kunci HMAC buku audit dipegang perwira siber satuan, tidak disimpan di laptop operator.
- **Internet:** tidak dibutuhkan setelah pemasangan.

Jalur laporan saat insiden

1. Operator jaga melihat peringatan dan menahan tombol isolasi.
2. Server menyegel bukti, memutus jalur, dan menerbitkan LAPSIT ke Dansat dan Kasi Siber.
3. Kasi Siber meneruskan LAPSIT (PDF) dan berita acara bukti ke Sansidam dan Kartika CSIRT. **Di purwarupa langkah ini masih manual.**
4. Kartika CSIRT menganalisis bukti dan, bila perlu, menyebarkan kabar ancaman baru ke satuan lain.

> **Kalimat siap pakai:** "Nusantara Shield dipasang di posko siber tiap rumah sakit TNI AD, satu server luring per satuan. Operatornya petugas TI rumah sakit atau Bintara Siber, dengan Dansat sebagai pengamat. Laporan dan bukti naik ke Sansidam dan Kartika CSIRT di Pussiberad. Jalur kirim otomatis ke pusat adalah langkah pengembangan berikutnya."

Bab 12 — Mengenal Dewan Juri dan Prediksi Pertanyaan

Nama anggota Dewan Juri belum diumumkan (per 20 Oktober 2026). Syarat dan Ketentuan resmi hanya menyebut Dewan Juri terdiri dari **unsur Pussiberad dan/atau praktisi/akademisi bidang keamanan siber dan kecerdasan buatan**. Karena itu,

persiapan terbaik adalah menyiapkan jawaban untuk lima tipe penanya, berdasarkan narasumber yang sudah diumumkan dan kriteria penilaian resmi.

Format yang perlu diingat

- **Babak penyisihan** dinilai daring mulai 16 November 2026 dari berkas kiriman. Batas akhir kiriman: **15 November 2026 pukul 23.59 WIB**.
- **10 finalis** diumumkan 20 November; babak final 24 November 2026 di Hotel Aston Kartika, Jakarta.
- Di final, setiap tim hanya punya **10 menit untuk penjelasan, demo langsung, dan tanya jawab sekaligus**. Usulan pembagian: 4 menit cerita, 3 menit demo, 3 menit tanya jawab.
- **Koreksi dari saya:** sebelumnya saya menyebut tim wajib 2–3 orang. Pasal 4.1 Syarat dan Ketentuan ternyata **membolehkan pendaftaran individu**. Jadi Bapak boleh maju sendiri; kolom nama anggota cukup diisi nama Bapak.

Kriteria penilaian resmi dan posisi kita

Aspek (bobot)	Yang dinilai	Posisi Nusantara Shield saat ini
Relevansi dan Manfaat (25%)	Kesesuaian dengan kebutuhan pengamanan IT/OT TNI AD	**Kuat.** IT/OT rumah sakit TNI AD, sabotase OT, isolasi tanpa mematikan genset.
Inovasi Teknis Berbasis AI (25%)	Keaslian ide dan pemanfaatan AI secara tepat guna	**Kuat.** Engine Deteksi Anomali (*Isolation Forest*) berjalan lokal dalam hitungan milidetik, menyebut alasannya (*explainability*), skornya masuk ke rumus peluang serangan, dan tetap di bawah kendali operator. Dikunci 10 uji khusus.
Fungsionalitas Purwarupa (25%)	Berjalan dan bisa didemonstrasikan	**Kuat.** Demo lengkap, 310 uji lulus, berjalan luring.
Kelayakan Implementasi (15%)	Potensi pengembangan dan kemudahan penerapan di satuan	**Sedang.** Bab 11 menjawabnya, tetapi belum tertulis di Proposal.
Kualitas Dokumentasi (10%)	Proposal, dokumentasi teknis, video demo	**Kuat**, setelah video demo selesai.

> **Catatan tentang AI:** tema resmi lomba adalah **"Pemanfaatan Kecerdasan Buatan (AI) untuk Mendukung Pengamanan IT/OT TNI AD"**, dan AI bernilai 25%. Per 20 Oktober 2026, komponen AI sudah dibangun: **Engine Deteksi Anomali** berjalan luring di *server* satuan, dan skornya ikut menentukan peluang serangan. Yang perlu dijaga saat presentasi adalah kejujuran: sebutkan bahwa ciri lalu lintasnya masih sintetis, dan bahwa **Engine Asisten Narasi** (LLM lokal untuk draf LAPSIT) masih peta jalan.

Catatan dari webinar pembukaan (19 Oktober 2026)

- **AI boleh dipakai, baik untuk membuat karya maupun di dalam karya.** Perwakilan CODEPOLITAN menyatakan peserta "boleh pakai AI atau apa pun". Jadi pemakaian Claude sebagai asisten pengembang sah, asalkan dicantumkan (pasal 5.4); atribusinya sudah ditambahkan di Proposal dan Dokumentasi Teknis.
- **Pussiberad ingin AI "dibenamkan" ke sistem operasional.** Danpussiberad menyebut AI sebagai peluang besar untuk **deteksi dini, analisis ancaman, dan respons insiden yang lebih cepat dan akurat**, dan menyatakan AI kini bukan sekadar alat bantu, melainkan bagian dari sistem operasional. Di Nusantara Shield, AI kini tertanam di alur operasional itu: skor anomalinya ikut menentukan peluang serangan dan muncul di log, sedangkan keputusan memutus tetap di tangan operator.
- **Kombinasi IT dan OT adalah tantangan yang beliau tekankan secara khusus.** Ini kekuatan terbesar kita (genset, Modbus, isolasi tanpa mematikan). Tonjolkan sejak menit pertama.
- **Juri akan menjalankan karya.** Dalam sesi tanya jawab dijelaskan bahwa yang penting karya berjalan dan bisa diuji Dewan Juri. Panduan pemasangan di Dokumentasi Teknis harus benar-benar bisa diikuti orang lain.
- **Peserta individu diperbolehkan.** Rencana awal minimal dua orang diubah menjadi minimal satu orang, sesuai pasal 4.1.

Daftar kiriman wajib (pasal 8.2)

- [ ] **Tautan repositori** yang bisa diakses Dewan Juri. Saat ini baru ada berkas zip; perlu repositori (misalnya GitHub) yang **tidak privat** selama penjurian (pasal 8.3).
- [ ] **Video demo purwarupa.** Naskahnya sudah ada; perekamannya belum.
- [x] ~~**Slide presentasi** yang memuat latar belakang, solusi, teknologi, dan potensi implementasi. Dek 6 slide; usulan penempatan sudah ditambahkan di Slide 6.~~
- [x] ~~**Dokumentasi teknis** berisi arsitektur, panduan pemasangan, dan cara penggunaan.~~
- [x] ~~**Proposal solusi** (disebut di webinar).~~
- [ ] **Nama tim** untuk formulir pendaftaran (wajib meski mendaftar sendiri, pasal 6.2).

Siapa yang mungkin duduk di depan Bapak

Nama-nama di bawah adalah **pembicara yang sudah diumumkan**, bukan juri yang dikonfirmasi. Gunakan sebagai gambaran tipe penanya.

Tipe penanya	Contoh orang yang diumumkan	Latar	Yang kemungkinan dikejar
Unsur Pussiberad	Danpussiberad Brigjen TNI Dr. Fransiscus Ari Susetio (pembicara pembukaan)	Pimpinan Pusat Siber TNI AD; pernah memberi kuliah tentang hukum dan perang kognitif	Siapa pemakainya, cocok dengan struktur, sah secara hukum, bisa diperluas
Praktisi AI	Sofian Hadiwijaya (pembicara utama)	*Applied AI Product Leader*, Forbes 30 Under 30 Asia, SVP di Superbank	Di mana AI-nya, apakah tepat guna, bisa dijelaskan atau tidak
Infrastruktur dan edukasi	Onno W. Purbo	Rektor ITTS, pelopor internet Indonesia, penulis 40+ buku TI	Biaya, sumber terbuka, perangkat sederhana, mudah diajarkan
Pertahanan praktis	Mahrus Qusaeri	Konsultan keamanan jaringan (NSE7, CCEP, CAP), mentor *ethical hacking* JagoanSiber	Sambungan ke *firewall* dan sakelar sungguhan, celah di dasbor sendiri
Forensik dan deteksi	Lettu Cpn Aghni Anugrah Raesa, S.Kom	Perwira TNI AD di Puspenerbad; pascasarjana keamanan siber di University of Queensland; peneliti forensik digital dan *detection engineering*	Keabsahan bukti, sumber data deteksi, cara aturan deteksi dibuat

Prediksi pertanyaan dan jawaban

A. Unsur Pussiberad (operasional dan doktrin)

Pertanyaan	Jawaban yang disarankan
Sistem ini dipasang di mana dan siapa operatornya?	Di posko siber tiap rumah sakit TNI AD, satu server luring per satuan. Operatornya petugas TI rumah sakit atau Bintara Siber; Dansat sebagai pengamat. Laporan naik ke Sansidam dan Kartika CSIRT (Bab 11).
Bagaimana kaitannya dengan Kartika CSIRT?	Nusantara Shield adalah alat di tingkat satuan; Kartika CSIRT tetap pusat penanganan. LAPSIT dan berita acara bukti diteruskan ke sana. Di purwarupa, penerusan masih manual lewat PDF.
Apakah bukti dari sistem ini sah untuk proses hukum?	Sistem menerapkan prinsip *chain of custody*: sidik jari SHA-256, berita acara bernomor, dan buku audit berantai HMAC. Namun keabsahan di pengadilan bergantung pada prosedur dan alat akuisisi resmi; di purwarupa, berkas buktinya masih tiruan.
Bagaimana bila diterapkan di banyak Kodam?	Karena satu server per satuan, penambahan satuan tidak membebani satuan lain. Yang belum dibangun adalah tampilan gabungan di tingkat Kodam dan pusat.
Bagaimana bila operator tidak ada di tempat?	Peringatan dan bukti tetap tercatat; pemutusan menunggu operator karena keputusan sengaja di tangan manusia. Karena itu diusulkan minimal dua Operator dan piket bergiliran.

B. Praktisi AI

Pertanyaan	Jawaban yang disarankan
Di mana pemanfaatan AI-nya?	Tunjukkan langsung: tekan **Latihan AI** di panel Prediksi CTI + AI. Genset naik ke WASPADA dengan alasan "perintah tulis Modbus 10× normal", tanpa kabar CTI apa pun. Lalu jelaskan: "AI kami adalah *Isolation Forest* yang dilatih dari lalu lintas normal di *server* satuan. Ia mengenali yang tidak wajar tanpa daftar *signature*, menilai 9 aset dalam sekitar 10 milidetik, dan selalu menyebut alasannya. Keputusan memutus tetap di tangan operator."
Kenapa tidak memakai pembelajaran mesin untuk deteksi?	Model yang tidak bisa dijelaskan berisiko memicu isolasi keliru pada aset vital. Karena itu AI kami hanya pemberi sinyal tambahan, bukan pengambil keputusan: ia menaikkan status dan menyebut alasannya, sedangkan operator tetap menahan tombol. Ambangnya juga diuji agar lalu lintas wajar tidak memicu alarm palsu, dan **Perketat** tetap bisa menurunkan peluangnya.
Bagaimana menghindari alarm palsu?	Korelasi hanya menaikkan aset yang benar-benar terkait (kabar *port* 502 hanya menyentuh aset *port* 502), dan ada uji khusus yang memastikan kabar IT tidak memicu OT dan sebaliknya.

C. Infrastruktur dan edukasi

Pertanyaan	Jawaban yang disarankan
Berapa biayanya?	Perangkat lunaknya memakai pustaka sumber terbuka (FastAPI, uvicorn, scikit-learn) dan cukup satu laptop: 2 inti, 512 MB memori bebas. Tanpa biaya langganan awan.
Bisakah prajurit tanpa latar TI mengoperasikannya?	Antarmuka memakai bahasa satuan (LAPSIT, Dansat, Kasi Siber) yang diatur dari satu kamus, ada Mode Edukasi, dan satu tombol utama. Pelatihan dasar tetap diperlukan.

Pertanyaan	Jawaban yang disarankan
Apakah kodenya terbuka?	Kode diserahkan lengkap kepada juri lewat repositori. Hak cipta tetap milik tim; Pussiberad berhak mengadopsi idenya sesuai pasal 14.3.

D. Pertahanan praktis

Pertanyaan	Jawaban yang disarankan
Apakah benar-benar bisa memutus *firewall* atau sakelar sungguhan?	Belum. Perintah ke sakelar masih simulasi *webhook*. Penerapan nyata membutuhkan sambungan terautentikasi ke perangkat jaringan satuan dan uji di lab dulu.
Data telemetrinya dari mana?	Di purwarupa, sintetis. Penerapan nyata membutuhkan sumber dari jaringan satuan, seperti catatan perangkat jaringan, ringkasan aliran (NetFlow), atau sensor deteksi intrusi.
Kenapa tidak otonom penuh, seperti "AI firewall otonom"?	Sengaja. Nusantara Shield adalah sistem pendukung keputusan. Di jaringan vital, respons otomatis penuh membuka tiga risiko: peringatan keliru yang memutus layanan sendiri, respons yang dapat dipancing pihak luar, dan pemutusan tanpa pejabat yang bertanggung jawab. Kecepatannya tetap terjaga: isolasi cukup ditahan 0,6 detik, dan pemutusan selesai ±1,2 detik dengan bukti disegel lebih dulu.
Selaras dengan kerangka apa?	NIST CSF 2.0. Keenam fungsinya (Govern, Identify, Protect, Detect, Respond, Recover) sudah diisi fitur yang berjalan, dan tiap kategori dirujuk ke uji yang membuktikannya (Dokumentasi Teknis §2.6). Itu pemetaan mandiri, bukan sertifikasi.
Bagaimana bila penyerang menyerang dasbornya?	Setiap permintaan melewati enam gerbang (ukuran, batas laju, login, peran, isian, aturan doktrin), kebijakan keamanan konten membatasi skrip, dan buku audit berantai HMAC membuat perubahan ketahuan. Servernya juga di jaringan tertutup.

Pertanyaan	Jawaban yang disarankan
Apakah serangan dipetakan ke MITRE ATT&CK?	Belum. Itu langkah pengembangan yang wajar untuk menyamakan bahasa dengan Kartika CSIRT.

E. Forensik dan deteksi

Pertanyaan	Jawaban yang disarankan
Alat apa yang dipakai untuk mengambil isi memori?	Di purwarupa, berkas bukti adalah tiruan bertanda SIMULASI. Integrasi alat akuisisi resmi adalah langkah penerapan berikutnya; yang sudah dikunci adalah **urutannya**: bukti dulu, sidik jari, baru putus.
Kenapa SHA-256 saja?	SHA-256 adalah standar yang lazim untuk integritas bukti digital. Menambah sidik jari kedua sesuai protap Kartika CSIRT mudah dilakukan.
Bagaimana keakuratan waktu dijaga?	Server mencatat waktu dalam UTC. Saat penerapan, jam server perlu disinkronkan ke sumber waktu internal satuan agar kronologi antarperangkat cocok.
Bagaimana aturan deteksi dibuat?	Engine Deteksi Aturan menghitung peristiwa mentah dengan ambang terbuka: 8 *login* gagal dari satu alamat dalam 60 detik, *login* berhasil sesudahnya, atau 15 kombinasi aset dan *port* dalam 10 detik. Di purwarupa peristiwanya sintetis; membacanya dari Active Directory, SIEM, atau sensor satuan adalah peta jalan berikutnya.

Bahasa juri: menyelaraskan istilah dengan buku Onno W. Purbo

Onno W. Purbo menulis puluhan buku keamanan siber yang Bapak kumpulkan. Yang paling dekat dengan proyek kita adalah *Cyber Warfare & Pertahanan Siber Indonesia* (bersama Gildas Deograt Lumy, 2025) dan seri *AI untuk SOC* (2026). Hitungan kata di buku-buku pertahanannya menunjukkan kosakata yang ia pakai: **server** (530 kali, "peladen" 0 kali), **dashboard** (420), **alert** (2.568), **triage**, **False Positive**, **MITRE ATT&CK**, **Wazuh** (2.250), dan **Ollama** (1.233). Dokumen kita sekarang memakai *server*, sama dengan aplikasi dan bukunya.

Istilah kita	Istilah di buku juri	Cara menyebutnya di depan juri
Peladen	*server*	"*server*" (sudah diganti di Proposal, Dokumentasi Teknis, dan dek)
Peringatan	*alert*	"peringatan atau *alert*"
Isolasi	*containment* (kontainmen)	"isolasi, tahap *contain*"
Amankan bukti	*chain of custody*, *hash verification* (SHA-256)	sama persis dengan Bab 10 bukunya
Pulihkan	*eradicate* dan *recover*	"pemulihan tanpa menghapus jejak forensik"
Evaluasi (langkah 7)	*After-Action Review* (AAR)	"Evaluasi, yaitu AAR"
Genset tetap menyala	*mission continuity*	"kontainmen tidak boleh mematikan fungsi layanan"
Peluang serangan per aset	*risk-based scoring*	"skor risiko per aset"
Posko siber satuan	*Cyber Defense Operation Center* (CDOC), **lapis taktis**	"CDOC tingkat satuan"
Peta Global, Action Center, Topologi	*strategic heatmap*, *operational incident board*, *tactical endpoint list*	tiga lapis tampilan pusat komando dari Bab 9 bukunya
Tombol ditahan operator	*human-in-the-loop*	"keputusan pemutusan tetap di tangan manusia"
Mode Berdaulat	kedaulatan digital, *air-gapped*, *on-premise*	"kedaulatan digital: semua berjalan di jaringan satuan"

Kerangka buku yang sudah sejalan dengan kita (sebut sebagai rujukan, bukan klaim baru):

- **OODA dan kecepatan keputusan.** Bab 2 bukunya berjudul "OODA Loop, C4ISR, dan *Speed of Decision*"; salah satu kutipan intinya: kecepatan komando adalah bentuk baru kekuatan api.
- **Tiga lapis komando siber:** strategis, operasional, dan taktis. Lapis taktis adalah CDOC di tingkat satuan, tempat Nusantara Shield berada.

- ***Incident response* militer (Bab 10):** *detect → contain → eradicate → recover*, *chain of custody* dengan SHA-256, dan AAR sebagai "ritual" setelah krisis. Bab ini menganjurkan alat sumber terbuka yang *air-gapped* atau *on-premise* dengan *audit trail* otomatis, persis prinsip kita.
- **AI untuk pertahanan (Bab 12):** deteksi anomali dengan *machine learning*, LLM lokal (Ollama) tanpa internet, *risk-based scoring*, *human-in-the-loop*, dan *explainability*. Bab ini juga mengingatkan bahwa *False Positive* bisa "menonaktifkan infrastruktur vital sendiri", alasan yang sama dengan tombol yang harus ditahan operator.

Pertanyaan khas yang mungkin muncul dari sudut pandang buku-buku beliau:

Pertanyaan	Jawaban yang disarankan
Kenapa tidak memakai Wazuh atau Suricata sebagai sumber data?	Tepat, itu langkah berikutnya. Nusantara Shield dirancang sebagai lapisan komando di atas sensor: Wazuh, Suricata, atau Zeek memberi *alert*, Nusantara Shield menegakkan urutan bukti, isolasi, laporan, dan pemulihan.
Bisakah bertukar CTI dengan BSSN atau Kartika CSIRT?	Rencananya lewat MISP atau OpenCTI dengan format STIX/TAXII, menggantikan rancangan Mode Hybrid. Belum dibangun.
Di mana AI-nya, dan apakah *air-gapped*?	Engine Deteksi Anomali (*Isolation Forest*) sudah berjalan di *server* satuan: itu *local inference*, tanpa API luar. Karena tidak membuka koneksi apa pun (dikunci uji yang memblokir jaringan), ia **siap** dipasang di jaringan *air-gapped*. LLM lokal untuk draf LAPSIT masih peta jalan. Ingat pesan buku beliau sendiri: *local inference* belum tentu *air-gapped*. Yang pertama soal di mana model dihitung, yang kedua soal jaringannya.
Bagaimana menekan *False Positive*?	Korelasi hanya menaikkan aset yang benar-benar terkait, ada uji yang mengunci "tanpa alarm palsu IT ⇄ OT", dan pemutusan tetap menunggu operator. Bila tetap muncul, Operator menutupnya dengan alasan tertulis yang tercatat di Buku Rantai Bukti (Bab 7).
Apakah semuanya sumber terbuka?	Ya: FastAPI, Uvicorn, ReportLab, pytest, HTTPX; tanpa CDN dan tanpa layanan awan. Atribusinya ada di Proposal bab 6.

Catatan keamanan: koleksi buku Bapak juga memuat buku uji penetrasi dan OSINT ofensif. Bagian itu tidak saya baca dan tidak dipakai, sesuai prinsip proyek yang murni defensif.

Tiga prinsip menjawab

1. **Jawab dulu, baru jelaskan.** Kalimat pertama adalah jawabannya ("Belum", "Di posko siber", "SHA-256").
2. **Bedakan yang sudah dan yang belum.** "Sudah berjalan dan dikunci uji" berbeda dengan "usulan". Juri teknis langsung tahu bila dikaburkan.

3. **Kembalikan ke doktrin.** Hampir semua jawaban bisa ditutup dengan: bukti dulu, baru putus; keputusan tetap di tangan manusia.

Sumber Bab 11 dan 12

- Syarat dan Ketentuan Kartika Cyber Hackathon 2026 v1.1 dan transkrip rekaman webinar pembukaan 19 Oktober 2026 (berkas di folder Bapak) dan situs resmi lomba
- Halaman acara pembukaan, CODEPOLITAN
- Profil Kartika CSIRT
- News FIN, 16 April 2026: rekrutmen Bintara Siber dan Sansidam Jaya
- Indonesiadefense, 15 April 2026: Pussiberad dan Kartika CSIRT
- Elitkita, Agustus 2026: kuliah umum Danpussiberad di STHM

Kamus Istilah A–Z

Semua istilah di panduan ini dalam satu tabel, urut abjad. Kolom terakhir menunjukkan bab tempat istilah itu dijelaskan panjang.

Istilah	Arti sederhana	Analogi	Bab
Action Center	Panel di dasbor tempat operator menjalankan langkah penanganan insiden	Meja komandan regu	3, 5
AI lokal (Engine Deteksi Anomali)	Kecerdasan buatan yang dilatih dan dihitung di server satuan sendiri, tanpa API di internet	Satpam yang dilatih di pos sendiri, bukan konsultan yang ditelepon	7
Air-gapped	Jaringan yang secara fisik tidak tersambung ke internet	Ruang arsip tanpa jendela	9
Alert fatigue	Kewalahan oleh terlalu banyak peringatan sampai yang penting terlewat	Alarm mobil yang terus berbunyi sampai tak dihiraukan	7
Alamat IP	Nomor unik setiap perangkat di jaringan	Nomor kamar	1
Anomali	Perilaku yang menyimpang dari kebiasaan	Tamu yang mencoba membuka pintu 24 kali	7

Istilah	Arti sederhana	Analogi	Bab
API	Deretan "loket" tempat layar dan server saling meminta data	Loket pelayanan	8
Aset	Perangkat atau sistem yang perlu dilindungi	Ruangan dan peralatan penting	1
Autentikasi	Membuktikan identitas dengan nama akun dan kata sandi	Menunjukkan KTA di pos jaga	9
Batas laju (*rate limit*)	Pembatasan jumlah percobaan dalam waktu tertentu	Tiga kali salah PIN, kartu diblokir	9
Berita acara (BB-2026-001)	Nomor resmi barang bukti yang sudah disegel	Label barang bukti polisi	5
Cadangan (*backup*)	Salinan data yang disimpan terpisah	Fotokopi arsip di lemari lain	2
Chain of custody	Catatan siapa memegang bukti, kapan, dan apa yang dilakukan	Buku serah terima barang bukti	5
CDN	Layanan luar untuk memuat huruf atau skrip situs web; tidak dipakai Nusantara Shield	Katering dari luar markas	9
CSF 2.0 (NIST)	Kerangka keamanan siber dengan enam fungsi: Govern, Identify, Protect, Detect, Respond, Recover	Daftar periksa kesiapan pos jaga	9
CTI	Kabar ancaman siber dari luar	Radio informasi antarpos	7
Dapur situasi	Bagian server yang menghitung gambaran situasi sekali per detik	Dapur umum	8
Delta (ralat)	Hanya bagian yang berubah yang dikirim ke layar	Ralat satu baris di koran	8
Enkripsi	Mengacak data dengan kunci rahasia	Gembok pada lemari	2

Istilah	Arti sederhana	Analogi	Bab
FastAPI	Kerangka kerja Python untuk membangun loket layanan	Cetakan untuk membuat loket	8
Forensik digital	Mengumpulkan dan memeriksa bukti dari perangkat komputer	Olah tempat kejadian perkara	5
***Hash* / SHA-256**	Sidik jari digital sebuah berkas; isi berubah, sidik jari berubah total	Sidik jari manusia	5
HMAC	Sidik jari yang dibuat dengan kunci rahasia; dipakai untuk merantai catatan	Segel lilin bercap	5
Insiden	Kejadian keamanan yang mengganggu layanan	Kebakaran atau pencurian	1
IOC	Jejak yang menandai penjahat: alamat IP, domain, sidik jari berkas	Foto dan ciri-ciri buronan	7
ISO/IEC 27037	Standar internasional penanganan bukti digital: identifikasi, pengumpulan, akuisisi, pelestarian	Buku petunjuk olah TKP versi digital	5
Isolasi	Memutus aset bermasalah dari jaringan	Menutup pintu darurat	4, 5
Isolasi Darurat (*Emergency Override*)	Pemutusan tanpa bukti bila alat forensik gagal; wajib beralasan	Membobol pintu saat kebakaran, lalu membuat laporan	5
Isolation Forest	Algoritma machine learning yang menemukan data tak wajar dengan memotong-motong data secara acak; yang aneh cepat terpisah	Satu orang berbaju merah di barisan berbaju hijau: cukup sedikit pertanyaan untuk menemukannya	7
IT	Teknologi yang mengurus data dan informasi	Bagian administrasi	6
Korelasi	Mencocokkan kabar ancaman dengan aset sendiri	Mencocokkan foto buronan dengan tamu	7

Istilah	Arti sederhana	Analogi	Bab
LAPSIT	Laporan situasi yang terbit otomatis ke pimpinan	Laporan piket ke komandan	3, 5
Local inference	Model AI dihitung di komputer sendiri. Tidak sama dengan *air-gapped* (jaringan tanpa internet)	Memasak di dapur sendiri; *air-gapped* berarti dapurnya juga tanpa pintu ke luar	7, 9
***Log* audit**	Buku harian sistem: siapa melakukan apa dan kapan	Buku mutasi piket	9
Luring	Berjalan tanpa internet	Radio lapangan tanpa menara	9
Machine learning	Cara komputer belajar pola dari contoh data, bukan dari aturan yang ditulis satu per satu	Satpam baru yang hafal kebiasaan kantor setelah mengamati berminggu-minggu	7
Modbus	Bahasa perintah mesin industri; tidak memeriksa pengirimnya	Perintah lisan tanpa cek identitas	6
MTTC (Mean Time To Contain)	Rata-rata waktu dari insiden dimulai sampai ancaman ditahan	Waktu dari alarm kebakaran berbunyi sampai api terkurung	7
Nilai Kesiapan Siber	Rapor A–E kesiapan layanan dan posko, dari dua sub-skor: Kerawanan dan Insiden	Rapor sekolah: nilai terendah yang menentukan	7
OODA	Siklus Amati, Orientasi, Putuskan, Bertindak	Siklus keputusan di medan tempur	4
On-premise	Dipasang di perangkat milik sendiri	Gudang sendiri, bukan sewa	9
OSINT	Intelijen dari sumber terbuka	Membaca koran dan pengumuman umum	7
OT	Teknologi yang mengendalikan mesin dan proses fisik	Ruang mesin dan panel listrik	6
Paparan	Seberapa terbuka sebuah aset terhadap serangan	Jumlah pintu yang tidak terkunci	7

Istilah	Arti sederhana	Analogi	Bab
Server	Komputer pusat yang melayani komputer lain	Gudang arsip pusat	1, 8
Pemindaian port (port scan)	Satu alamat mencoba banyak port dalam waktu singkat untuk mencari layanan yang terbuka	Orang asing mencoba gagang setiap pintu di lorong	7
Peran	Hak akses akun: Pengamat (melihat) atau Operator (bertindak)	Tamu dan petugas jaga	3, 9
Perketat (*hardening*)	Menutup pintu yang tidak perlu agar aset sulit diserang	Mengunci jendela yang tidak dipakai	7
Playbook	Daftar langkah baku penanganan insiden	Protap pemadaman kebakaran	3, 4
Port	Pintu layanan bernomor pada sebuah perangkat	Loket bernomor di dalam kamar	1
Praotorisasi	Izin diberikan sebelum kejadian, bukan saat panik	Protap yang sudah ditandatangani	4
Ransomware	Program jahat yang mengunci data lalu meminta tebusan	Penyusup yang menggembok lemari arsip	2
RFC 5737	Blok alamat IP khusus untuk contoh dan dokumentasi	Nomor telepon fiktif di film	3
Sakelar terkelola	Perangkat simpang jaringan yang bisa dibuka-tutup dari jauh	Penjaga pintu antarzona	6
Sistem pendukung keputusan (SPK)	Sistem yang menyiapkan informasi dan pilihan tindakan; keputusan tetap di tangan manusia	Perwira staf menyiapkan peta, komandan yang memutuskan	3
Skor anomali	Angka 0 sampai 1 dari AI lokal; di atas 0,58 dianggap tidak wajar	Termometer: di atas batas berarti demam	7

Istilah	Arti sederhana	Analogi	Bab
SOAR	Otomatisasi langkah respons insiden sesuai *playbook*	Regu pemadam yang bergerak sesuai protap	5
SOC	Pusat operasi keamanan siber	Ruang kendali pos jaga	3
SSE	Siaran satu arah dari server ke semua layar	Siaran radio	8
Token	Kartu tanda masuk sementara setelah login	Kartu tamu	9
Triase peringatan	Operator menutup peringatan WASPADA sebagai Selesai ditangani atau *False Positive*, wajib beralasan	Buku piket satpam saat mematikan alarm	7
Uji otomatis (pytest)	Daftar periksa yang dijalankan komputer	Daftar periksa pilot sebelum terbang	8
Uplink	Kabel penghubung jaringan kantor ke zona kendali	Lorong penghubung dua gedung	6
UU ITE	Undang-Undang Informasi dan Transaksi Elektronik; Pasal 30 melarang mengakses sistem orang lain tanpa hak	Larangan masuk pekarangan orang tanpa izin	3
UU PDP	Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi	Kewajiban menjaga buku tamu agar tidak dibaca sembarang orang	3
WASPADA	Status aset berisiko (peluang ≥50%) sebelum ada serangan	Siaga satu	7
Webhook	Pesan perintah otomatis dari satu sistem ke sistem lain; di purwarupa masih simulasi	SMS perintah otomatis	6
Zona	Pembagian jaringan menjadi wilayah berpenjaga	Bangsal dengan pintu berpenjaga	6

Tambahan: istilah dari buku Onno W. Purbo yang sebaiknya Bapak kenali dan pakai saat menjawab juri.

Istilah	Arti sederhana	Kaitannya dengan Nusantara Shield
***After-Action Review* (AAR)**	Tinjauan setelah insiden: akar masalah, perbaikan, dan pembaruan *playbook*	Langkah terakhir *playbook* (Evaluasi)
CDOC (*Cyber Defense Operation Center*)	Pusat operasi pertahanan siber di lapis taktis	Posko siber satuan tempat Nusantara Shield dipasang
***Containment* (kontainmen)**	Menahan ancaman agar tidak menyebar	Isolasi IT dan pemutusan jalur OT
Eradicate	Membersihkan semua jalan masuk penyerang	Sebelum Pulihkan; jejak forensik tidak boleh hilang
Explainability	Hasil AI bisa dijelaskan kepada komandan	Alasan yang ditulis AI lokal, misalnya "login gagal 24× normal"
False Positive (Positif Palsu)	Alarm yang ternyata bukan ancaman	Dicegah korelasi; bila tetap muncul, Operator menutupnya dengan alasan tertulis (Bab 7)
Fusion cell	Ruang yang menggabungkan semua data intelijen untuk keputusan cepat	Tingkat pusat (Kartika CSIRT, Pussiberad)
Lapis taktis, operasional, strategis	Tiga lapis komando siber: satuan, pusat operasi, pimpinan	Nusantara Shield di lapis taktis
LLM lokal / Ollama	Model bahasa AI yang berjalan di komputer sendiri tanpa internet	Peta jalan: penyusun draf LAPSIT (belum ada di purwarupa)
Isolation Forest	Algoritma *machine learning* untuk menemukan data yang tidak wajar	**Sudah berjalan:** Engine Deteksi Anomali lalu lintas
MISP / OpenCTI, STIX/TAXII	Platform dan format standar untuk berbagi kabar ancaman	Rencana penghubung dengan BSSN dan Kartika CSIRT

Istilah	Arti sederhana	Kaitannya dengan Nusantara Shield
Mission continuity	Fungsi tempur atau layanan harus tetap berjalan selama penanganan	Genset tetap menyala saat Sabotase OT
MITRE ATT&CK	Katalog cara-cara penyerang yang dipakai sedunia	Rencana pemetaan *alert*
MTTD, MTTC, MTTR	Rata-rata waktu mendeteksi, menahan, dan memulihkan	Dasbor sudah menampilkan MTTC
Risk-based scoring	Memberi skor risiko agar insiden terpenting ditangani dulu	Peluang serangan per aset
Triage	Memilah *alert* mana yang ditangani dulu	Korelasi CTI dan status WASPADA
Wazuh, Suricata, Zeek	Alat sumber terbuka untuk memantau komputer dan lalu lintas jaringan	Rencana sumber telemetri nyata

Uji Pemahaman

Jawab dengan kata-kata sendiri, sebaiknya diucapkan keras-keras seolah menjawab juri. Centang bila sudah lancar. Kunci jawaban ada di bawah.

- [ ] 1. Apa pelajaran utama dari kasus PDNS 2024?
- [ ] 2. Kenapa proyeksi ancamannya rumah sakit, bukan kantor biasa?
- [ ] 3. Sebutkan empat tahap OODA dan tahap mana yang tetap di tangan manusia.
- [ ] 4. Kenapa bukti harus diamankan sebelum jaringan diputus?
- [ ] 5. Apa itu SHA-256, dan apa yang terjadi bila satu huruf berkas diubah?
- [ ] 6. Apa beda IT dan OT? Beri satu contoh masing-masing di rumah sakit.
- [ ] 7. Kenapa genset tidak dimatikan saat Sabotase OT?
- [ ] 8. Bagaimana kabar CTI-109 bisa menaikkan genset ke WASPADA 66%?
- [ ] 9. Apa arti "praotorisasi" dan kenapa tombolnya harus ditahan 0,6 detik?
- [ ] 10. Apa yang dimaksud "satu dapur, satu pengeras suara"?
- [ ] 11. Apa saja yang belum dibangun di purwarupa?
- [ ] 12. Bagaimana menjawab bila juri bertanya "apakah ini pakai AI?"

Kunci jawaban

1. Tanda bahaya sudah ada dua hari sebelumnya, tetapi tidak berbuah tindakan. Masalahnya kecepatan dan prosedur, bukan ketiadaan data.
2. Di rumah sakit IT dan OT bertemu, dan gangguannya menyangkut nyawa. Data kesehatan juga bernilai tinggi bagi penyerang (kasus 279 juta data, 2021), dan Winnipeg 2026 membuktikan OT rumah sakit sudah diserang.
3. Amati, Orientasi, Putuskan, Bertindak. Tahap **Putuskan** tetap di tangan operator.
4. Isi memori hilang bila komputer dimatikan, dan pemulihan bisa menghapus jejak. Tanpa bukti, insiden tidak bisa ditelusuri.
5. Sidik jari digital sebuah berkas. Satu huruf berubah, sidik jarinya berubah total, sehingga perubahan langsung ketahuan.
6. IT mengurus data (SIMRS, rekam medis); OT mengendalikan mesin (genset, pendingin udara, kelistrikan ruang operasi).
7. Ruang operasi dan ICU bergantung padanya. Yang diputus adalah jalur jaringan kantor ke zona kendali; genset tetap menyala dengan kendali lokal.
8. Keyakinan 0,80 × paparan 0,75 × kesegaran 1,0 × bonus sektor 1,1 = 0,66. Karena di atas ambang 50%, genset naik WASPADA.
9. Izin diberikan sebelum kejadian, jadi operator tidak menunggu tanda tangan saat panik. Menahan 0,6 detik mencegah salah pencet, tetapi lebih cepat dari jendela "Anda yakin?".
10. Server menghitung gambaran situasi sekali per detik untuk semua layar dan hanya menyiarkan ralatnya. Hasilnya, 300 layar hanya membebani CPU sekitar 1,5% (diukur ulang pada versi akhir).
11. Sambungan ke sakelar dan genset sungguhan (*webhook* masih simulasi), sensor protokol industri, Mode Hybrid untuk kabar ancaman resmi, dan operasi multiproses. Semua data juga masih sintetis.
12. Ya. Engine Deteksi Anomali (*Isolation Forest*, scikit-learn) berjalan lokal di *server* satuan tanpa API luar. Skornya ikut menentukan peluang serangan, beserta alasan yang bisa dibaca. AI hanya menaikkan status; keputusan memutus tetap di tangan operator. Model bahasa untuk draf LAPSIT masih peta jalan, dan asisten AI juga dipakai pengembang saat menulis kode.